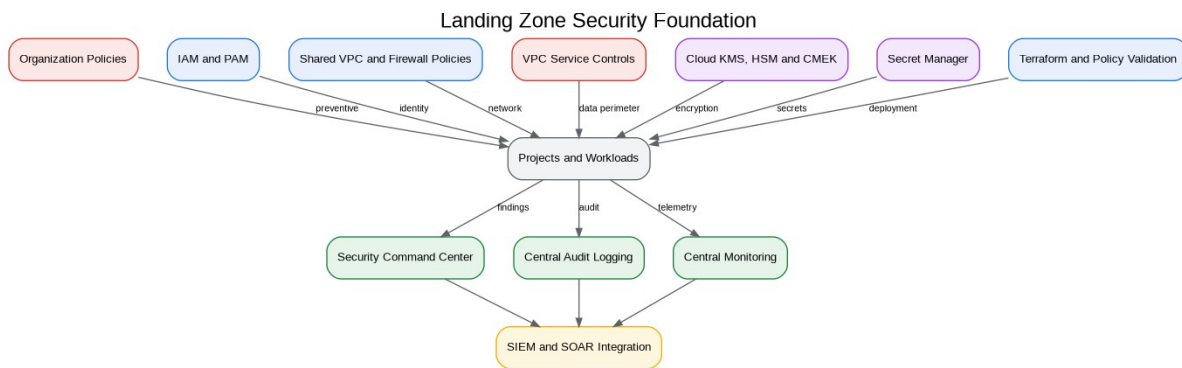


ENTERPRISE GOOGLE CLOUD DATA PLATFORM BLUEPRINT

VOLUME 02 - Google Cloud Landing Zone

Enterprise Cloud Architecture Team

July 2026



Landing Zone Security Foundation

Secure, scalable and automated enterprise cloud foundation

Fortune 100 scale | Multi-region | Hybrid and multi-cloud | Regulated workloads

Version 1.0 | Architecture baseline

Contents

Executive Landing Zone Overview
Organization, Folder and Resource Hierarchy
Project Factory, Project Types and Environment Strategy
Enterprise Network Architecture
Identity and Access Architecture
Security Foundation
Audit, Monitoring, Logging and Security Operations
Naming Conventions, Labels and Tags
Terraform Landing-Zone Implementation
Landing-Zone Deployment Sequence
Landing-Zone Validation Checklist
Architecture Decision Records
Service Reference Cards
Operating Model and RACI
Risks and Mitigations
Production Readiness Review
Appendices and Control Evidence

Document Control

This volume defines the resource, network, identity, security, observability and automation foundation required before enterprise data, analytics and AI workloads are onboarded to Google Cloud. It is a reusable implementation baseline for a Fortune 100 organization and is intended to be tailored through controlled architecture decisions rather than copied without validation.

Field	Value
Document title	Enterprise Google Cloud Data Platform Blueprint - Volume 02: Google Cloud Landing Zone
Document type	Enterprise reference architecture and implementation guide
Version	1.0
Status	Reference baseline for architecture and security review
Audience	Cloud Center of Excellence, enterprise architecture, security, networking, platform engineering, SRE and audit
Scope	Organization structure through Terraform deployment and validation
Inherited baseline	Volume 01 enterprise assumptions, service strategy and operating model
Primary objective	Create a governed cloud foundation that enables workload teams to deploy without recreating core controls
Assurance cadence	Quarterly control review, annual resiliency exercise and event-driven review after material platform or regulatory change

Revision History

Version	Date	Authoring body	Change
0.1	July 2026	Landing Zone Architecture Team	Initial detailed baseline
0.8	July 2026	Network and Security Architecture	Control and topology review
0.9	July 2026	Platform Engineering	Terraform and deployment validation
1.0	July 2026	Architecture Review Board	Reference baseline issued

How to Use This Volume

Enterprise architects should use the hierarchy, environment and boundary decisions as the design authority for workload onboarding. Network and security teams should use the control matrices as configuration requirements. Platform engineering should use the Terraform module catalog and deployment sequence as the implementation backlog. Audit and risk teams should use the validation checklist and evidence requirements to assess whether the landing zone is fit for production.

Product availability, quotas, pricing, supported regions, VPC Service Controls compatibility and organization-policy behavior must be validated against current Google Cloud documentation before implementation. Official references are listed in Appendix E.

1. Executive Landing Zone Overview

The landing zone is the enterprise control plane for Google Cloud adoption. It establishes the resource hierarchy, identity boundaries, network topology, security guardrails, centralized telemetry and automated project creation that

every workload inherits. A strong landing zone reduces delivery lead time because teams receive a pre-approved foundation. A weak landing zone simply relocates fragmented data-center practices into disconnected cloud projects.

The recommended design uses a centrally governed, regionally segmented resource hierarchy. Production, non-production, development and sandbox environments are separated at folder, project, IAM, network and key-management layers. Shared VPC host projects centralize network control while service projects preserve workload ownership and cost attribution. Hybrid and multi-cloud routes converge through an enterprise connectivity layer using redundant Cloud Interconnect or Partner Interconnect attachments, HA VPN as backup and Network Connectivity Center where hub-and-spoke orchestration is justified.

Human access is federated from the enterprise identity provider and granted through groups. External workforce identities use Workforce Identity Federation when synchronized Google identities are neither required nor desirable. External workloads, CI/CD systems and non-Google cloud runtimes use Workload Identity Federation and short-lived credentials instead of service-account keys. Privileged access is request-based, time-bound and approval-controlled through Privileged Access Manager or an equivalent approved process.

Preventive controls are implemented through organization policies, hierarchical firewall policies, policy validation in CI/CD and project-factory defaults. Detective controls are implemented through Security Command Center, centralized audit logs, network telemetry, Cloud Monitoring, SIEM integration and posture checks. Restricted data projects are placed inside VPC Service Controls perimeters after dry-run validation, with precise ingress and egress rules rather than broad perimeter bridges.

1.1 Design outcomes

Outcome	Target state	Executive evidence
Faster onboarding	A standard project is delivered in less than one business day after approvals	Project-factory service-level dashboard
Reduced security variance	Mandatory controls are inherited automatically and exceptions expire	Policy compliance and exception register
Private-by-default access	No public IPs or public data endpoints without explicit approval	Asset inventory and network posture report
Credential risk reduction	No user-managed service-account keys for standard workloads	IAM inventory and key-creation policy
Auditability	Organization-wide audit and security events are routed centrally	Log sink, retention and SIEM evidence
Regional compliance	Projects, keys, data and networks align to approved geographies	Resource-location and residency attestations
Cost ownership	Every project maps to a cost center, domain and environment	Billing export and label coverage dashboard

1.2 Scope

The landing zone includes:

Google Cloud organization, folders and project boundaries.

Project factory and environment-specific project patterns.

Shared VPC, IP addressing, routing, private service access, DNS and edge protection.

Hybrid and multi-cloud connectivity.

Human, partner and workload identity federation.

IAM, service accounts, privileged access and break-glass controls.

Organization policies, VPC Service Controls, Security Command Center, secrets and encryption.

Central logging, monitoring and security-operations integration.

Naming, labels, tags and automated cost attribution.

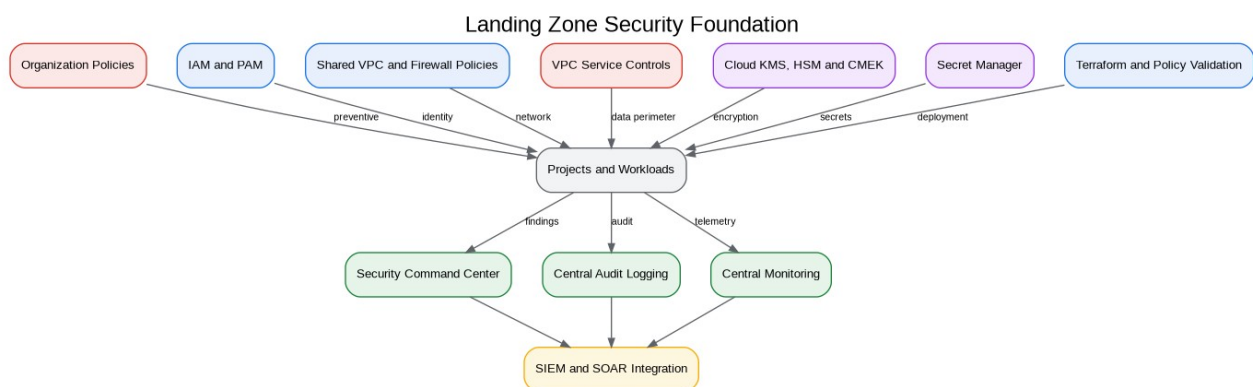
Terraform implementation, deployment sequencing and acceptance testing.

1.3 Mandatory and adaptable decisions

Decision class	Mandatory baseline	Adaptable by geography or business unit
Identity	Federated identity, group-based IAM and no standing broad privilege	Identity-provider protocol and regional support processes
Network	Shared VPC or explicitly approved isolated VPC; private access by default	Number of host projects and hub topology
Security	Organization policies, centralized logging, SCC and controlled keys	Specific constraints and security service tier
Data perimeter	Restricted workloads are evaluated for VPC Service Controls	Perimeter boundaries and supported service set
Automation	Project creation and foundational changes use reviewed infrastructure as code	Repository topology and CI/CD execution platform
Resilience	Redundant connectivity and tested recovery for critical control-plane services	Regions, bandwidth and failover mode

1.4 Fortune 100 assumptions

Area	Assumption
Organization	Global enterprise with multiple legal entities, business units and regulated workloads
Regions	AMER, EMEA and APAC regional groups with primary and recovery regions by workload tier
Identity	Enterprise IdP provides authoritative lifecycle events and strong authentication
Connectivity	At least two major data centers and existing AWS and Azure footprints
Operations	Central Cloud Center of Excellence, network operations, security operations and platform engineering
Delivery	Terraform is the primary infrastructure-as-code tool and changes flow through CI/CD
Security	Restricted data requires stronger access, perimeter, encryption and monitoring controls
Scale	Hundreds to thousands of projects over the lifetime of the platform



Landing zone control plane

2. Organization, Folder and Resource Hierarchy

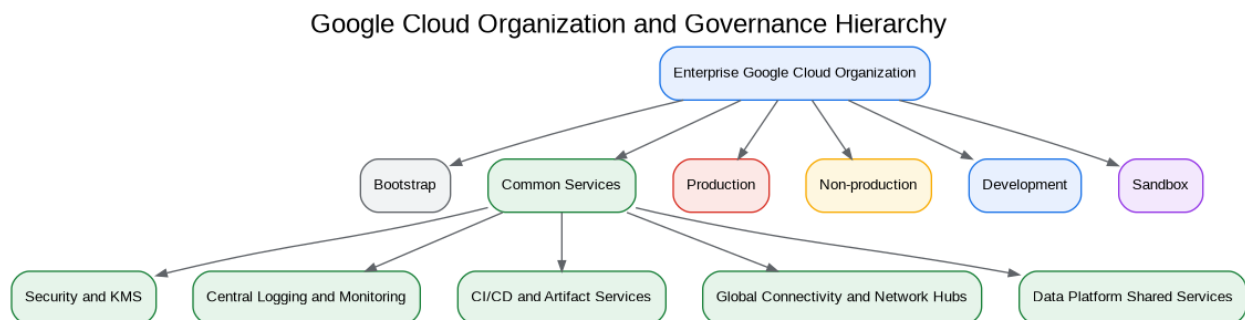
The resource hierarchy is a security and governance structure, not merely a visual filing system. Policies inherited at organization and folder levels create the enterprise default. Projects form the primary workload, billing, API, quota and blast-radius boundary. Folders should therefore reflect durable control boundaries such as environment, regulatory geography and administrative ownership rather than temporary programs or reporting lines.

2.1 Google Cloud organization structure

Use a single primary Google Cloud organization unless legal separation, merger transition or sovereign control requires an additional organization. One organization maximizes policy inheritance, centralized security visibility and consistent identity governance. Additional organizations introduce cross-organization sharing complexity, duplicated controls and fragmented incident response; each requires an explicit federation and exit strategy.

Hierarchy node	Purpose	Primary administrators	Policy role
Organization	Enterprise control boundary and root for managed resources	Cloud foundation administrators and security governance	Enterprise constraints, logging sinks, SCC activation and access policy
Bootstrap folder	Seed projects, Terraform state, automation identities and foundation pipelines	Platform engineering with security oversight	Highly restricted; minimal services; no workload data
Common folder	Shared network, security, logging, monitoring, artifact and platform services	Central platform teams	Shared-service controls and explicit cross-environment access
Environment folders	Production, non-production, development and sandbox isolation	Environment platform owners	Environment-specific constraints, firewall delegation and budgets
Geography folders	Residency and operating partition within an environment	Regional platform and compliance owners	Location, key, routing and data-boundary controls
Domain folders	Optional grouping for large domains with durable delegated ownership	Domain platform leads	Delegated project creation and bounded IAM
Projects	Workload, billing, API and quota boundary	Project owner group, never an individual	Service enablement, IAM and workload-specific configuration

2.2 Folder hierarchy



Organization and top-level folders

The baseline uses environment folders as the main policy boundary because production and non-production require different controls, support models and change procedures. Geography folders beneath each environment isolate regional resources and allow location policies, key projects, logging retention and local operating responsibilities to be applied consistently. Domain folders are optional and should be introduced only when a business domain owns enough projects to justify delegated administration.

Reference	Folder	Purpose	Administration	Key controls
fld-bootstrap	Bootstrap	Terraform state, seed project and foundation CI/CD	Foundation administrators only	No workload data; restricted egress
fld-common	Common	Shared security, networking, logging and platform services	Central platform teams	Cross-environment access through explicit service identities
fld-prod	Production	Production workloads and services	Production operations and domain leads	Strict change control and restricted public access
fld-nonprod	Non-production	Integration and pre-production validation	Engineering and test teams	Production-like controls with lower availability
fld-dev	Development	Developer integration and engineering experimentation	Development teams	Reduced data sensitivity and time-bound resources
fld-sandbox	Sandbox	Short-lived exploration and training	Users through managed sandbox groups	No restricted data; quotas and automatic expiry
fld-quarantine	Quarantine	Acquired, compromised or unassessed projects	Security operations	Network isolation and denied deployment
fld-retired	Retired	Projects retained for audit before deletion	Platform operations	No active workload and defined deletion schedule

2.3 Resource hierarchy design rules

Durability over organizational fashion

Folder structures must remain stable through reorganizations. Use labels, billing views, catalog metadata and CMDB relationships for reporting dimensions that change frequently. Resource moves should be exceptional because inherited IAM, policies, networking and billing controls can change when a project moves.

Policy-first design

Create folders because a distinct policy, administrative boundary or lifecycle exists. Avoid adding hierarchy layers that carry no inherited control or delegated responsibility. Every folder must have a named owner, purpose, policy inventory and lifecycle.

No direct user ownership

Projects and folders are managed by groups and automation identities. Direct individual grants are limited to time-bound or emergency cases. Group membership is governed by the enterprise identity process and reviewed at a cadence proportional to privilege.

Controlled inheritance

Use inheritance for mandatory controls and explicit exceptions for verified needs. Broad deny policies that force unmanaged shadow environments are a failure of design. Exceptions must have a named owner, business justification, compensating control, expiry date and remediation target.

Project as blast-radius boundary

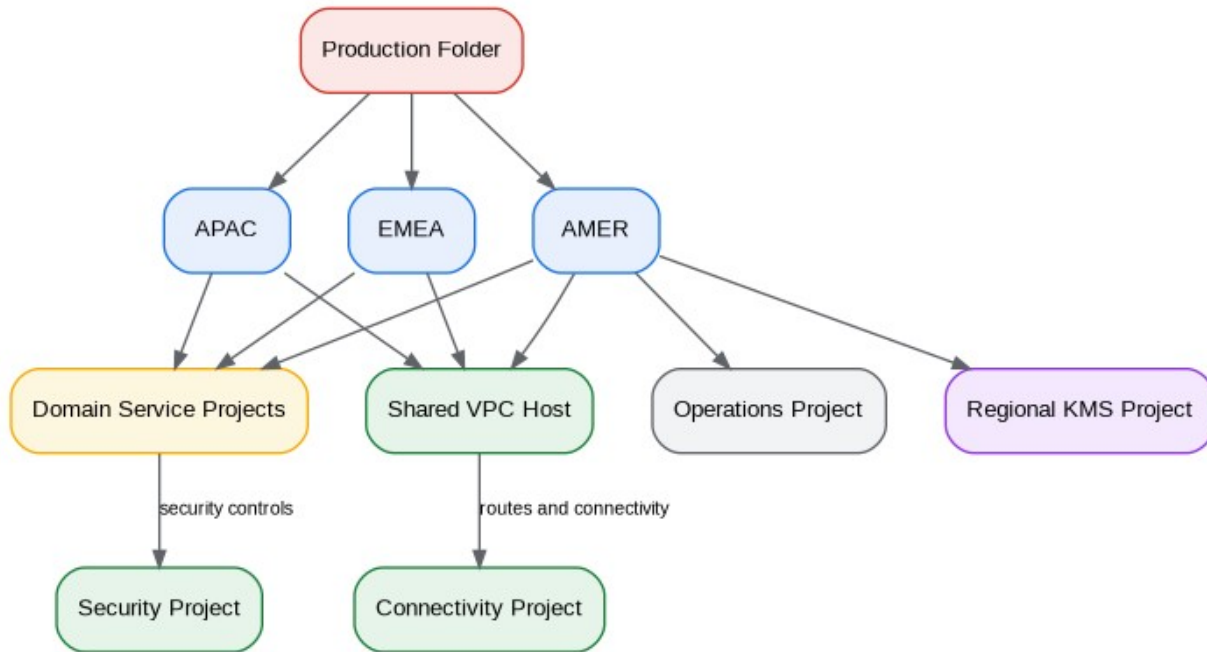
Separate materially different security classes, ownership models, availability tiers and financial responsibilities into distinct projects. Avoid both extremes: one project for the entire platform and a project for every minor microservice.

Acquisition containment

Newly acquired resources enter a quarantine or transitional folder until identity, network, logging, policy and ownership alignment is verified. Quarantine is an operating state with explicit remediation tasks, not a permanent destination.

2.4 Environment, geography and project hierarchy

Folder and Project Hierarchy by Environment and Geography



Folder and project hierarchy

A geography folder represents a durable policy and operational partition. It can host regional Shared VPC projects, KMS projects, logging views and domain service projects. A domain may span multiple geographies, but data and service projects remain in the geography that satisfies residency and recovery requirements.

2.5 Anti-patterns

Anti-pattern	Why it fails	Preferred correction
One project for the data platform	Broad IAM, quota contention, weak cost attribution and large blast radius	Separate shared platform projects from domain and environment projects
Folder per application	Excessive depth and policy complexity	Use projects for workload boundaries and folders for durable governance boundaries
Business-unit hierarchy only	Reorganizations force resource moves and policy changes	Place stable environment and geography controls above optional domain folders
Multiple unmanaged organizations	Fragmented logging, policy, identity and security visibility	Use one primary organization or formal cross-organization governance
Individual project owners	Lifecycle and accountability risk	Use role-based groups and automation identities
Manual project creation	Inconsistent APIs, labels, networks and security controls	Require the project factory and policy validation

3. Project Factory, Project Types and Environment Strategy

The project factory is the landing-zone product interface. It converts approved metadata into a correctly located, billed, networked, monitored and governed Google Cloud project. It must be operated as a production service with versioned modules, automated tests, approval workflows, rollback procedures and published service levels.

3.1 Project-factory workflow

A requester submits project metadata: business domain, application, environment, geography, data classification, cost center, owner group, support tier and requested services.

Automated policy validates naming, location, service compatibility, network attachment, perimeter requirements and budget metadata.

Domain, security, networking, finance and platform approvals are collected according to risk.

Terraform creates the project, links billing, enables approved APIs, attaches the correct Shared VPC, applies labels, configures logging and creates baseline service accounts.

Automated tests verify inherited organization policies, private networking, log routing, monitoring visibility, IAM, quotas and budget alerts.

The project is registered in the CMDB and relevant catalogs. Ownership is transferred to the workload team within the approved boundaries.

The factory should expose a declarative request model rather than a collection of manual tickets. A request can originate in a service portal, Git pull request or API, but the resulting configuration must be source controlled and replayable. The factory must be idempotent: rerunning the same request should converge on the approved state rather than creating duplicate resources.

3.2 Project types

Project type	Purpose	Placement	Administration
Bootstrap seed	Foundation state, deployment identities and initial CI pipeline	Common/Bootstrap	No workload data; tightly restricted administrators
Network host	Shared VPC networks, subnets, routes, DNS and firewall policies	Per environment and geography	Central network administration
Connectivity	Cloud Routers, Interconnect VLANs, VPN gateways and NCC hubs	Common and regional	Network operations
Security management	SCC, security posture, access policies and automation	Common	Security engineering and SOC
KMS	Regional key rings, keys and HSM-protected material	Per geography/environment or sensitivity	Key administrators separated from key users
Central logging	Aggregated log buckets, sinks and exports	Common	Security operations and audit
Central monitoring	Metrics scopes, dashboards, uptime checks and alert routing	Common or per environment	SRE and platform operations
CI/CD	Build pools, artifact storage and deployment automation	Common or per environment	Platform engineering
Artifact	Artifact Registry and trusted software artifacts	Common or per environment	Platform engineering and security
Data platform shared	Shared ingestion, governance, orchestration and platform services	Per environment/geography	Data platform product team
Domain data	Business-domain data products and pipelines	Per domain/environment/geography	Domain data-product team
Analytics	BI, notebooks, semantic models and analytical services	Per domain/environment	Analytics team
AI/ML	Vertex AI training, registry, endpoints and AI governance	Per domain/environment/geography	AI platform and model owners

Project type	Purpose	Placement	Administration
Application service	Operational application components attached to the shared network	Per application/environment	Application team
Sandbox	Time-bound individual or team experimentation	Sandbox folder	Automatic expiry; no restricted data
Quarantine	Isolated project under investigation or acquisition onboarding	Quarantine folder	Security operations only

3.3 Shared-services projects

Shared services reduce duplication but increase dependency concentration. Each shared service therefore requires explicit SLOs, versioned interfaces, tenancy controls, recovery procedures and capacity management. The common folder must not become a miscellaneous location for resources with unclear ownership.

Shared service	Recommended project boundary	Availability target	Consumer model
Network and connectivity	Separate host and connectivity projects per environment/geography	Tier 0	Subnet attachment, routes and private endpoints
KMS and HSM	Separate key projects by geography and criticality	Tier 0	Service agents receive only encrypt/decrypt permissions
Logging	Central storage project plus environment views	Tier 0/1	Aggregated sinks and controlled log views
Monitoring	Central metrics scope with delegated dashboards	Tier 1	Read visibility to workload telemetry
CI/CD	Foundation pipeline separate from workload pipelines	Tier 0	Federated deployment identities and approved roles
Artifact Registry	Environment or trust-zone repositories	Tier 1	Immutable artifacts and vulnerability controls
Security automation	SCC findings, posture and remediation automation	Tier 0/1	Findings routed to SOC and ticketing
Data platform shared	Catalog, ingestion templates and orchestration control services	Tier 1	Published platform APIs and templates

3.4 Environment model

Environment	Purpose	Access	Support	Control posture
Development	Feature development, unit testing and integration with synthetic or masked data	Developer groups and automation	Business hours	Small quotas and automatic shutdown where possible
Test	System integration, security and data-quality validation	Test engineers and deployment identities	Business hours plus release windows	Production-like configuration at reduced scale
Staging	Production rehearsal, performance testing and release validation	Restricted engineering and operations	Extended support during releases	Production topology and controls with smaller capacity

Environment	Purpose	Access	Support	Control posture
Production	Business operations and governed data products	Operations, approved domain teams and automation	24x7 for Tier 0/1	Strict change, capacity and recovery controls
Sandbox	Training, experimentation and short-lived proofs of concept	Named users through managed sandbox groups	Best effort	No restricted data; budget and expiry enforcement
Disaster recovery	Regional recovery components and replicated configuration	Operations and recovery automation	Activated during tests or incidents	Capacity aligned to RTO and failover design

Environment promotion applies to code and policy, not to manually configured resources. Terraform modules, organization-policy bundles, firewall policies and monitoring definitions are promoted through versioned releases. Environment-specific values are externalized in reviewed configuration. Direct production changes are denied except through a controlled break-glass process and must be reconciled back into source control.

3.5 Development environment

Development projects are optimized for engineering speed without weakening the enterprise boundary. They use synthetic, masked or low-sensitivity data. Developers receive broader service-level roles inside their project but no network-host, organization-policy or perimeter-administration privileges. Resource quotas and default budgets are intentionally small. Temporary resources are deleted automatically based on labels and expiration dates.

Development should be sufficiently similar to production to expose policy and network incompatibilities early. It should not be a completely disconnected environment in which developers rely on public endpoints, service-account keys and manually created resources that will be prohibited later.

3.6 Test and staging environments

Test validates integration, security, data quality and operational procedures. Staging is the production rehearsal environment and should use the same topology, organization policies, private connectivity, identity model, encryption approach and deployment pipeline as production. Capacity may be smaller, but differences must be explicit and documented.

Tests should include service-perimeter access, key disable and restore, route failover, log delivery, monitoring, privileged access, project-factory onboarding and rollback. Staging cannot be considered production-like if it bypasses the controls most likely to cause production deployment failures.

3.7 Production environment

Production projects require named service ownership, support tier, SLOs, runbooks, capacity plan, DR classification and a reviewed exception register. Production IAM is granted through automation or time-bound entitlements. Production networks use private access and controlled egress. Public exposure is implemented only through approved edge projects, load balancers and Cloud Armor policies.

Changes require an approved plan, automated tests and post-deployment validation. Emergency changes are allowed only through break-glass procedures and must be reconciled into source control after the incident.

3.8 Sandbox environment

Sandbox projects are isolated from production networks and restricted data. They use low budgets, restrictive quotas and automatic expiration. The sandbox is not a route around architecture governance: it is a safe place to learn, test APIs and evaluate services with public, synthetic or explicitly approved data.

Mandatory sandbox controls include:

- Dedicated sandbox folders and projects.

- No production or restricted datasets.

- No service-account keys or broad external identities.

- No direct connectivity to production networks.

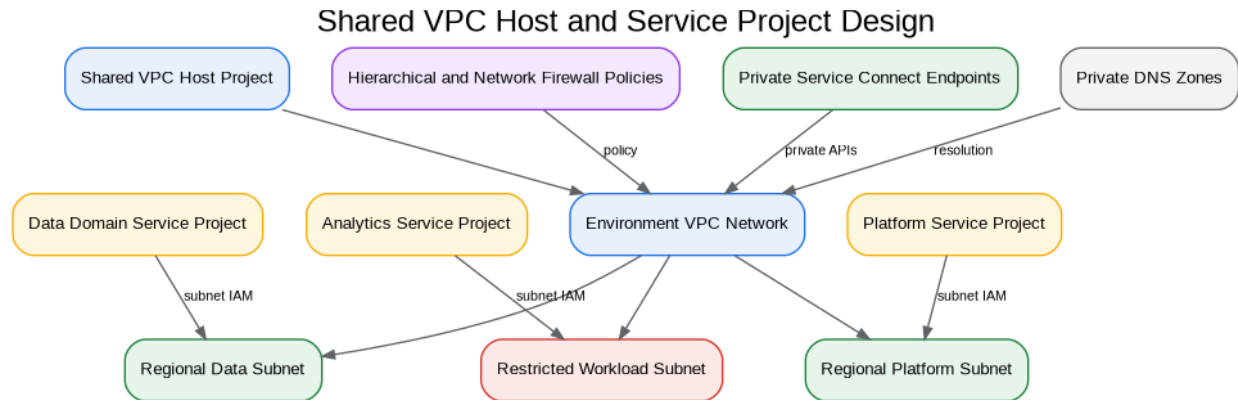
- Budget alerts and automatic cleanup.

A maximum lifetime unless renewed by an owner.

4. Enterprise Network Architecture

The network architecture centralizes routing, policy, private service access and hybrid connectivity while allowing service projects to retain workload ownership. The baseline uses Shared VPC host projects per environment and geography, service projects for workloads, global dynamic routing where appropriate, centralized DNS and private endpoints for Google APIs. A connectivity hub provides controlled reachability between on-premises, multi-cloud and environment spokes.

4.1 Shared VPC design



Shared VPC design

Shared VPC separates network administration from workload administration. Network teams own networks, subnets, routes, firewall policies, DNS and private endpoints in host projects. Workload teams deploy resources in service projects and receive `compute.networkUser` only on approved subnets. Subnet-level grants are preferred over host-project-wide grants because they limit future access as networks expand.

Design element	Baseline decision	Rationale	Exception trigger
Host-project count	One host project per environment and regulatory geography	Limits blast radius and residency complexity while preserving central control	Very small geography with no regulated workloads
Network count	One primary custom-mode VPC per host project; additional restricted VPC only when isolation requires it	Reduces route and policy complexity	Distinct trust zone or incompatible routing requirements
Service projects	Separate by domain, application, environment and material security class	Preserves IAM, quota and cost boundaries	Tiny tightly coupled components with the same owner and lifecycle
Subnet IAM	Grant network user at subnet level	Least privilege and predictable future access	Platform service requiring every subnet in a host project
Default network	Do not create or retain default networks	Avoids permissive defaults and unmanaged topology	None
Routing mode	Global for enterprise connected networks and regional for isolated local networks	Enables predictable multi-region route propagation	Regulatory requirement to prevent inter-region routing

4.2 Host-project design

Host projects contain only network control-plane resources and approved network appliances. They should not contain business applications, data processing jobs or user-managed compute. This separation prevents workload administrators from changing routing or firewall controls and keeps network lifecycle independent of service-project lifecycle.

A host project contains:

- Shared VPC networks and regional subnets.

- Cloud Routers and dynamic routing configuration.

- Private Service Connect endpoints and service attachments owned by the network team.

- Cloud DNS policies, forwarding zones and private zones.

- Hierarchical and network firewall-policy associations.

- Cloud NAT gateways for approved egress.

- VPC Flow Logs and network telemetry settings.

- Proxy-only subnets required by supported managed load balancers.

Host projects must have a more restrictive IAM model than workload projects. Workload owners can request subnets and firewall intents through approved interfaces, but they do not receive permissions to change the host network directly.

4.3 Service-project design

A service project owns billable workload resources and remains the primary operational and cost boundary. It attaches to one Shared VPC host project for its environment and geography. The project factory enables only approved services, grants subnet access to required service agents, registers the project in monitoring and logging scopes, and places it inside a VPC Service Controls perimeter when required.

A service project can use its own standalone VPC only when isolation, service compatibility or legal requirements cannot be met through the approved Shared VPC pattern. Standalone networks must still use central IPAM, logging, DNS, private access, firewall and connectivity standards.

4.4 IP-addressing strategy

Address space is allocated from enterprise IPAM and remains non-overlapping with on-premises and other clouds. Contiguous blocks are reserved by geography and environment so routes can be summarized. Secondary ranges are allocated only for services that require them and are sized based on measured growth.

Allocation	Enterprise block	Typical regional allocation	Use
AMER production	10.16.0.0/12	10.16.0.0/16 per region	Regional platform, data, application and restricted subnets
EMEA production	10.32.0.0/12	10.32.0.0/16 per region	Residency-aligned workloads
APAC production	10.48.0.0/12	10.48.0.0/16 per region	Residency-aligned workloads
Global non-production	10.64.0.0/12	/17 or /18 per region/environment	Integration, test and staging
Development	10.80.0.0/12	/18 per region	Development and ephemeral workloads
Sandbox	10.96.0.0/13	/20 per region	Restricted scale and short-lived resources
Connectivity and transit	10.104.0.0/16	/24 per attachment or service	Routers, appliances, proxy and endpoint ranges
Future reserve	10.112.0.0/12	Unallocated	Acquisitions, sovereign zones and growth

These ranges are illustrative. Production allocation must be reconciled with existing enterprise address space. Reusing overlapping ranges across clouds creates long-term routing, NAT and observability complexity and should be avoided.

IP design rules

Register every CIDR in the enterprise IPAM system before Terraform deployment.

Prefer aggregateable ranges and avoid fragmented allocations unless a service requires them.

Reserve dedicated ranges for proxy-only subnets, PSC endpoints and hybrid appliances.

Do not reuse overlapping RFC 1918 ranges across clouds if routed connectivity is expected.

Monitor subnet and secondary-range exhaustion as an SLI.

Treat IPv6 adoption as a controlled roadmap and validate service-specific support.

4.5 Subnet strategy

Pattern	Purpose	Indicative size	Control baseline
sn-data	Data processing and managed service connectors	/22 to /20	Private Google Access, flow logs and no direct internet
sn-platform	Orchestration, platform services and shared tooling	/23 to /21	Restricted administration and service-to-service rules
sn-app	Operational applications and APIs	/23 to /20	Load-balancer and approved service ingress only
sn-restricted	Regulated or high-sensitivity workloads	/24 to /22	Tighter firewall and perimeter controls
sn-proxy	Regional proxy-only subnet	Service-defined minimum	Dedicated to managed load-balancer proxies
sn-psc	Private Service Connect endpoints	/24 or IPAM-defined	Reserved endpoints and private DNS records
sn-gke-pods	GKE pod secondary range	Capacity-driven	Separate from nodes; exhaustion monitoring
sn-gke-services	GKE service secondary range	Capacity-driven	Separate and treated as immutable design input
sn-management	Network appliances and management services	/26 to /24	Highly restricted administrative access

Subnets are not created for organizational convenience. Each subnet has a traffic purpose, route expectations, firewall policy, logging requirement, owner, capacity forecast and lifecycle. Reusing a generic subnet for unrelated trust zones makes firewall and incident analysis significantly harder.

4.6 Routing strategy

The routing design uses regional Cloud Routers, dynamic BGP, route advertisements aligned to enterprise address summaries, and explicit control of transitive connectivity. The landing zone does not assume that all environments or geographies can communicate. Routes express approved connectivity; firewall policy expresses permitted traffic; identity and service controls provide additional authorization.

Routing principles

Use regional dynamic routing unless a documented cross-region requirement justifies global dynamic routing.

Advertise summarized enterprise prefixes wherever possible.

Do not import default routes from on-premises without explicit egress design and security approval.

Use route priorities consistently and reserve ranges for emergency or migration paths.

Keep production, non-production, restricted and sandbox route domains separable.

Use Network Connectivity Center or an equivalent hub-and-spoke control plane when connectivity scale exceeds direct attachment management.

Monitor BGP session state, learned-prefix count, route changes and asymmetric paths.

Validate every failover route under production-like load before go-live.

Route domain	Imported prefixes	Exported prefixes	Default route policy	Primary use
Production	Approved data-center, partner and cloud ranges	Production summaries only	No inherited internet default	Business-critical workloads
Non-production	Development and test dependencies	Non-production summaries	Controlled central egress	Integration and testing
Restricted	Minimal approved dependencies	Restricted summaries	No internet path by default	Regulated data services
Sandbox	Shared utility endpoints only	None or narrow ranges	Cloud NAT with domain controls	Experimentation
Connectivity	Enterprise transit ranges	Aggregated spoke prefixes	Not a workload domain	Hybrid and multi-cloud transit

Route intent is stored as code and reviewed with the same rigor as firewall policy. A route change that broadens reachability is treated as a security-impacting change.

4.7 Private Google Access

Private Google Access is enabled on subnets that host workloads without external IP addresses. It allows supported resources to reach Google APIs and services without traversing the public internet from a workload perspective. DNS policy determines whether clients use standard, private or restricted Google API endpoints.

Control pattern

Enable Private Google Access on all approved workload subnets.

Configure private DNS for googleapis.com according to service-perimeter and egress requirements.

Prefer restricted API endpoints for workloads inside high-sensitivity service perimeters when supported.

Block direct external IP assignment through organization policy except for approved exception projects.

Capture VPC Flow Logs and DNS query logs for investigation and assurance.

Validate service-specific endpoint behavior before production deployment.

Private Google Access is not an authorization mechanism. IAM, resource policy, service perimeter rules and application authentication remain mandatory.

4.8 Private Service Connect

Private Service Connect is the preferred pattern for privately consuming supported Google APIs, managed services and producer services across VPC boundaries without broad network peering. It provides endpoint-based service exposure while preserving producer and consumer network autonomy.

Enterprise usage patterns

Pattern	Producer	Consumer	Landing-zone control
Google APIs endpoint	Google-managed APIs	Workload VPC	Central DNS, endpoint IP allocation and policy validation
Published internal service	Shared platform or domain service	Other enterprise VPCs	Service attachment, consumer allow-list and logging
Third-party managed service	Approved vendor	Enterprise workload	Contracted service attachment and security review
Cross-organization service	Acquired company or partner	Enterprise domain	Explicit trust boundary and data-processing agreement

Best practices

Allocate PSC endpoint addresses from dedicated ranges.

Register endpoints in enterprise DNS with stable names.

Approve producers and consumers explicitly; do not rely on discoverability alone.

Apply firewall and application-layer authorization in addition to endpoint reachability.

Monitor endpoint connection state, service attachment acceptance and backend health.

Use separate endpoints for production and non-production.

Document service-specific limitations, supported regions and VPC Service Controls compatibility.

Common pitfalls

Treating PSC as a replacement for IAM or API authentication.

Publishing a service from a network with uncontrolled lateral reachability.

Reusing endpoint IP ranges without IPAM registration.

Failing to plan DNS cutover and rollback.

Assuming all managed services expose identical PSC capabilities.

4.9 Cloud NAT

Cloud NAT supplies controlled outbound internet connectivity for private workloads that cannot use private APIs or PSC. It is deployed regionally, associated with dedicated Cloud Routers and configured only for subnets or address ranges with approved egress requirements.

Control	Standard
External IPs	Static enterprise-owned addresses where allow-listing is required
Port allocation	Dynamic or manually sized from measured concurrency and destination patterns
Logging	Errors always; translations sampled or fully logged based on risk and cost
High availability	Regional managed service with multiple external addresses where needed
Scope	Explicit subnet ranges, not indiscriminate all-subnet enablement
Egress filtering	Secure web proxy, next-generation firewall or application controls as required
Monitoring	Port exhaustion, dropped packets, allocation failures and unexpected destinations

Cloud NAT does not inspect payloads or provide domain-aware filtering. High-risk internet access therefore uses an approved secure egress architecture.

4.10 Cloud DNS

Cloud DNS provides authoritative private zones, forwarding zones, peering zones and enterprise name resolution. DNS is a security and availability dependency and is managed centrally.

DNS architecture

Global public zones remain in dedicated perimeter-controlled projects.

Private zones are associated with approved networks by environment and geography.

Inbound forwarding supports on-premises resolution of private Google Cloud names.

Outbound forwarding resolves enterprise zones through redundant on-premises or cloud resolvers.

Response policies implement controlled overrides and protective blocks.

PSC and private API endpoint names are created through automated modules.

DNS logging is enabled for high-value networks and integrated with security analytics.

Naming zones

Zone	Example	Purpose
Enterprise private	corp.example.internal	Shared enterprise services
Production workload	prod.gcp.example.internal	Production service discovery
Non-production	nonprod.gcp.example.internal	Development, test and staging
PSC	psc.gcp.example.internal	Private managed and producer endpoints
Restricted	restricted.gcp.example.internal	Regulated service resolution
Reverse	in-addr.arpa managed zones	Investigation and operational tooling

DNS changes use code review, staged deployment and rollback records. Manual console changes are disallowed except through audited emergency procedures.

4.11 Firewall policies

Firewall policy follows a deny-by-default, intent-based model. Hierarchical policies establish enterprise guardrails, network firewall policies provide shared workload controls, and application controls provide protocol-level authorization.

Policy layers

Layer	Owner	Purpose	Examples
Organization	Enterprise security	Non-bypassable global controls	Deny known malicious ranges; restrict administration
Folder	Platform security	Environment or jurisdiction policy	Deny production-to-sandbox; restrict regulated folders
Network	Network security	Shared VPC traffic intent	Allow load balancer health checks; domain service flows
Workload	Application/domain team	Application-specific authorization	Service-to-service ports and identity-aware access
Host/application	Workload team	Local defense	Host firewall, mTLS and application authorization

Firewall rule standard

Every rule must contain:

Business and technical purpose.

Source and destination identities or address ranges.

Protocol and port.

Direction and priority.

Environment and data classification.

Owner and support group.

Expiration or review date.

Ticket or architecture decision reference.

Logging requirement.

Test and rollback evidence.

Broad rules such as 0.0.0.0/0, all protocols, unrestricted SSH/RDP, or tag-based access without ownership require an approved exception and expiration.

4.12 Hierarchical firewall policies

Hierarchical firewall policies provide centrally administered controls inherited by folders and projects. The landing zone uses them for controls that must not be weakened by workload teams.

Baseline policy intents

Deny direct administrative access from the internet.

Deny unauthorized cross-environment traffic.

Permit only approved health-check ranges to load-balanced backends.

Permit centralized security scanners from defined service identities and ranges.

Permit hybrid management paths from approved administration networks.

Deny known high-risk destinations and command-and-control indicators where technically appropriate.

Require logging for all explicit denials and high-risk allows.

Use threat-intelligence feeds or managed controls only with documented ownership and false-positive handling.

Policy priorities are reserved in blocks so enterprise, geography, environment and exception rules can coexist predictably. Emergency deny rules use a reserved highest-precedence range.

4.13 Cloud Armor

Cloud Armor protects internet-facing and approved cross-boundary applications behind supported Google Cloud load balancers. The standard combines preconfigured WAF rules, adaptive protection where justified, rate limiting, IP and geography controls, and organization-defined threat intelligence.

Capability	Landing-zone standard
Baseline WAF	OWASP-aligned preconfigured rules tuned in preview before enforcement
Rate limiting	Per-client and endpoint-aware policies for abuse protection
Bot controls	Applied to approved high-risk applications after business-impact analysis
Policy hierarchy	Enterprise baseline plus application-specific policy
Logging	Request logs with policy outcome routed to central security analytics
Change model	Policy as code with preview, test and staged enforcement
Exception handling	Named owner, narrow condition, expiry and compensating control

Cloud Armor is not applied to services that are not behind a supported load-balancing path. API authorization, identity-aware access, application security and secure coding remain necessary.

4.14 Cloud VPN and Cloud Interconnect

The hybrid design uses two connectivity tiers:

HA VPN for rapid deployment, backup, lower-throughput sites and encrypted internet-based connectivity.

Dedicated or Partner Cloud Interconnect for predictable enterprise throughput, latency and private connectivity.

Connectivity selection matrix

Requirement	HA VPN	Dedicated Interconnect	Partner Interconnect
Rapid provisioning	Strong	Moderate/long lead	Moderate
Low bandwidth	Suitable	Usually excessive	Suitable
High and predictable throughput	Limited by tunnel design	Strong	Strong, provider dependent

Requirement	HA VPN	Dedicated Interconnect	Partner Interconnect
Direct physical connectivity	No	Yes	Through provider
Enterprise facility presence	Not required	Required at supported location	Not necessarily required
Encryption over path	IPsec built in	Add MACsec/IPsec where required and supported	Depends on provider/design
Typical use	Backup, branches, pilots	Strategic data centers	Sites without colocation presence

Resilience pattern

Deploy redundant connections in separate edge availability domains.

Use independent customer routers and power paths.

Use multiple VLAN attachments and Cloud Routers.

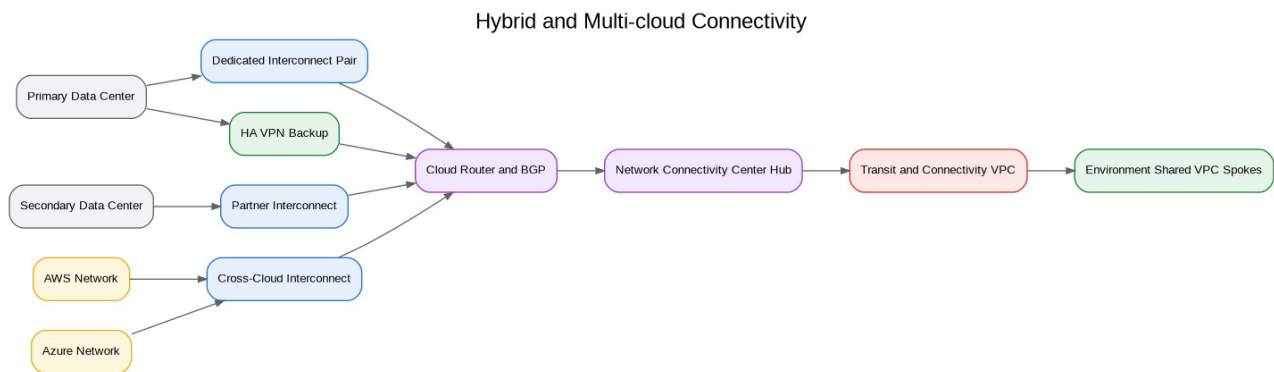
Establish HA VPN as an independent backup where business impact warrants it.

Validate BGP convergence, route withdrawal and session failure.

Define maximum tolerated packet loss, latency and convergence time.

Capacity test at expected peak plus growth margin.

4.15 Hybrid connectivity



Hybrid and Multi-Cloud Connectivity

The enterprise connectivity hub integrates data centers, branch networks, partner networks, Google Cloud regions and approved other clouds. Network Connectivity Center is used where it simplifies hub-and-spoke connectivity and centralized route management. The control plane is not assumed to create transitive trust; each spoke remains subject to route, firewall, identity and data controls.

Hybrid traffic classes

Traffic class	Example	Required controls
Data ingestion	Database CDC, file transfer, event streams	Private route, encryption, source authentication and reconciliation
Administration	CI/CD, security tooling, break-glass support	Privileged identity, hardened path and session audit
Application integration	APIs, messages and service calls	mTLS/OAuth, rate limits and contract testing
Monitoring	Metrics, logs and traces	Central collectors, restricted write identities and retention policy
Backup/recovery	Recovery copies and configuration	Segregated identities, immutability and restore tests

4.16 Multi-cloud connectivity

Multi-cloud connectivity is designed as explicit service integration rather than broad network extension. AWS and Azure networks connect through approved private links, VPN, interconnect partners or internet-secured endpoints according to latency, volume, sovereignty and provider capability.

Multi-cloud principles

- Avoid creating a single flat RFC 1918 estate.
- Prefer service-level integration and event exchange over unrestricted east-west routing.
- Allocate non-overlapping address ranges across clouds.
- Centralize route ownership and incident telemetry.
- Apply consistent identity federation and workload identity patterns.
- Control data transfer through approved gateways and data contracts.
- Model egress cost and recovery dependencies before production adoption.
- Test provider and carrier failure independently.

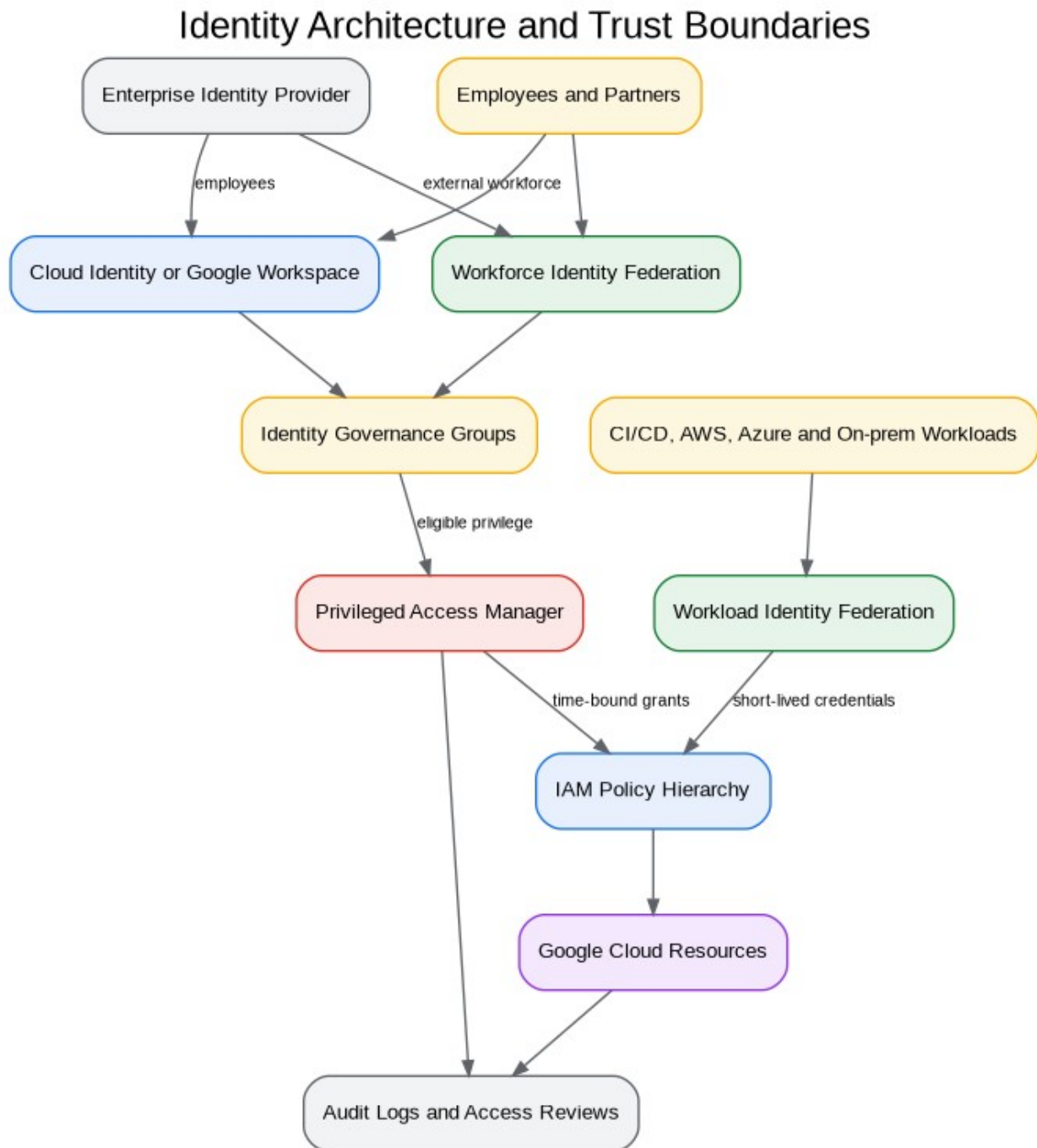
4.17 Network segmentation

Segmentation uses multiple complementary boundaries:

- Organization and folder policy boundaries.
- Separate production and non-production Shared VPCs.
- Separate restricted-data networks and service perimeters.
- Regional subnets with explicit route and firewall controls.
- Project-level workload isolation.
- Identity-aware service authorization.
- Application-level mTLS and policy where required.
- Data-level authorization and masking.

A network boundary is not treated as sufficient protection for sensitive data. The design assumes compromised credentials, misconfigured workloads and insider risk, and therefore combines identity, data and service controls.

5. Identity and Access Architecture



Identity and Trust Boundaries

5.1 Identity architecture objectives

The identity foundation ensures that every action is attributable to a verified human or workload identity, access is time-bounded where practical, and permissions are granted at the lowest sustainable scope. The model separates workforce, workload, external partner and emergency identities.

Identity type	Source of truth	Authentication	Authorization pattern
Employees	Enterprise HR and IdP	Federated SSO and MFA	Group-based IAM and PAM
Contractors	Approved identity provider	Federated SSO, MFA and expiry	Separate groups, sponsor and time limit
External partners	Partner IdP or workforce pool	Workforce Identity Federation	Attribute conditions and narrow roles
CI/CD workloads	GitHub, Cloud Build or enterprise CI	Workload Identity Federation	Dedicated deployment service accounts
Runtime workloads	Google Cloud service identities	Service account or workload identity	Per-service least privilege
Emergency administrators	Dedicated break-glass identities	Strong MFA and monitored use	Minimal emergency roles and expiry

5.2 Cloud Identity

Cloud Identity provides the Google Cloud workforce directory and group foundation. It integrates with the enterprise identity provider and receives authoritative lifecycle events from HR and identity governance systems.

Standards

User accounts are not created manually for normal workforce access.

Joiner, mover and leaver events propagate through automated provisioning.

Administrative identities are separate from daily productivity identities where required.

High-privilege groups cannot be self-managed by their members.

Group ownership is assigned to accountable business and technical owners.

Dormant accounts and groups are reviewed and removed.

Authentication context and MFA strength reflect access sensitivity.

5.3 Workforce Identity Federation

Workforce Identity Federation is used when external or non-Google workforce identities require Google Cloud access without creating long-lived Google-managed user accounts. Attribute mappings and conditions restrict which subjects, groups and claims can assume permissions.

Design controls

Create separate workforce pools by trust domain or partner class.

Map immutable subject identifiers rather than mutable display names.

Require signed, time-limited assertions from approved identity providers.

Use attribute conditions to limit organization, group, employment state and assurance level.

Grant access to groups or principal sets at the narrowest resource scope.

Log token exchange and resource access.

Define revocation and partner-termination procedures.

5.4 Workload Identity Federation

Workload Identity Federation is the standard for GitHub Actions, external CI/CD, on-premises workloads and other-cloud workloads that need Google Cloud access. It avoids downloadable service-account keys and exchanges trusted external credentials for short-lived Google credentials.

Required pattern

Create a dedicated workload identity pool per external trust domain.

Configure a provider for the external token issuer.

Map repository, branch, environment, organization, workload or cloud-account claims.

Restrict token exchange with attribute conditions.

Grant the federated principal permission to impersonate a dedicated service account.

Grant that service account only the deployment or runtime permissions required.

Monitor token exchanges, impersonation and downstream API calls.

Long-lived service-account keys are prohibited by organization policy except for documented legacy exceptions with rotation, storage and retirement plans.

5.5 IAM groups

Groups represent job function, support responsibility or approved data-consumer populations. They are not created per individual project when an enterprise role already exists.

Group naming examples

Group	Purpose
<code>gcp-org-security-admins@example.com</code>	Organization security policy administrators
<code>gcp-net-prod-operators@example.com</code>	Production network operators
<code>gcp-landingzone-builders@example.com</code>	Landing-zone CI/CD approvers and operators
<code>gcp-data-customer-engineers@example.com</code>	Customer-domain engineering team
<code>gcp-breakglass-org@example.com</code>	Emergency organization administrators
<code>gcp-auditors-readonly@example.com</code>	Enterprise audit and assurance

Each privileged group has an owner, deputy, membership criteria, review frequency, maximum membership expectations and emergency removal procedure.

5.6 IAM roles

Predefined roles are preferred when they align with duties. Custom roles are created only to remove material excess privilege or to define stable enterprise job functions. Basic roles such as Owner and Editor are prohibited for routine access.

Role-design rules

Separate policy administration, resource creation, workload operation and security review.

Grant at folder level only when the role is legitimately common to every child project.

Prefer resource-level or project-level grants for workload teams.

Use conditions for time, resource name or approved context when practical.

Test custom-role permissions through automated integration tests.

Review deprecated and newly added permissions before role updates.

Maintain role definitions as code.

5.7 Service accounts

Every service account has a single workload purpose, named owner, project, environment and lifecycle. Shared or human-used service accounts are not permitted.

Control	Requirement
Creation	Through approved Terraform modules
Naming	<code>sa-<workload>-<function>-<env></code> within service constraints
Authentication	Attached identity or federation; no downloaded keys by default

Control	Requirement
Impersonation	Granted to named CI/CD or operator groups only
Permissions	Minimum required roles at minimum scope
Monitoring	Authentication, impersonation and API activity logged
Review	Quarterly for privileged identities; semiannual otherwise
Retirement	Disabled, observed, then deleted after dependency validation

Service agents created by Google Cloud services are handled separately from customer-managed service accounts and receive only documented required permissions.

5.8 Privileged Access Manager

Privileged Access Manager provides time-bound, approval-based elevation for eligible human administrators. Entitlements define who can request which roles, at what scope, for how long and with which approvers.

Standard workflow

Operator authenticates with strong MFA.

Operator requests a defined entitlement and states business justification.

Required approvers review the request.

The platform grants temporary access for the approved duration.

Activity is logged and correlated with the request.

Access expires automatically.

High-risk use receives post-access review.

Permanent organization-level administrative grants are reduced to the smallest emergency and platform-governance population.

5.9 Break-glass access

Break-glass access supports loss of federation, widespread policy failure or critical security response. It is not a convenient substitute for normal privileged access.

Break-glass controls

At least two dedicated emergency identities, stored and managed independently.

Phishing-resistant MFA and offline recovery procedures.

Minimal roles required to restore identity, policy and logging control.

Credentials protected in an enterprise privileged-access vault.

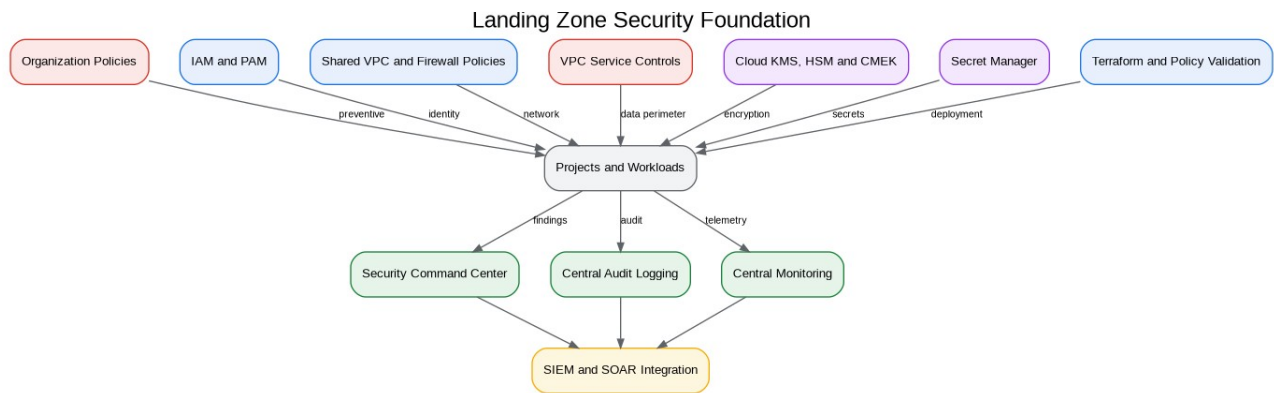
Immediate security notification on authentication or use.

Mandatory incident record and post-use review.

Quarterly credential validation without unnecessary privilege exercise.

Semiannual end-to-end tabletop and annual controlled technical test.

6. Security Foundation



Security Foundation

6.1 Security control model

The landing zone establishes preventive, detective and corrective controls at organization, folder, project, network, service and data layers.

Control class	Examples	Evidence
Preventive	Organization policy, IAM constraints, VPC SC, firewall deny	Policy state and denied test
Detective	Security Command Center, audit logs, flow logs, DNS logs	Findings, alerts and query evidence
Corrective	Automated quarantine, rollback, access removal	Incident and automation records
Recovery	Terraform rebuild, key recovery, log archive	Recovery test evidence
Governance	Exceptions, ownership, reviews and control mapping	Approval and attestation records

6.2 Organization policies

Organization Policy Service enforces non-negotiable resource constraints. Policies are version-controlled, tested in lower-risk folders and deployed through approved pipelines.

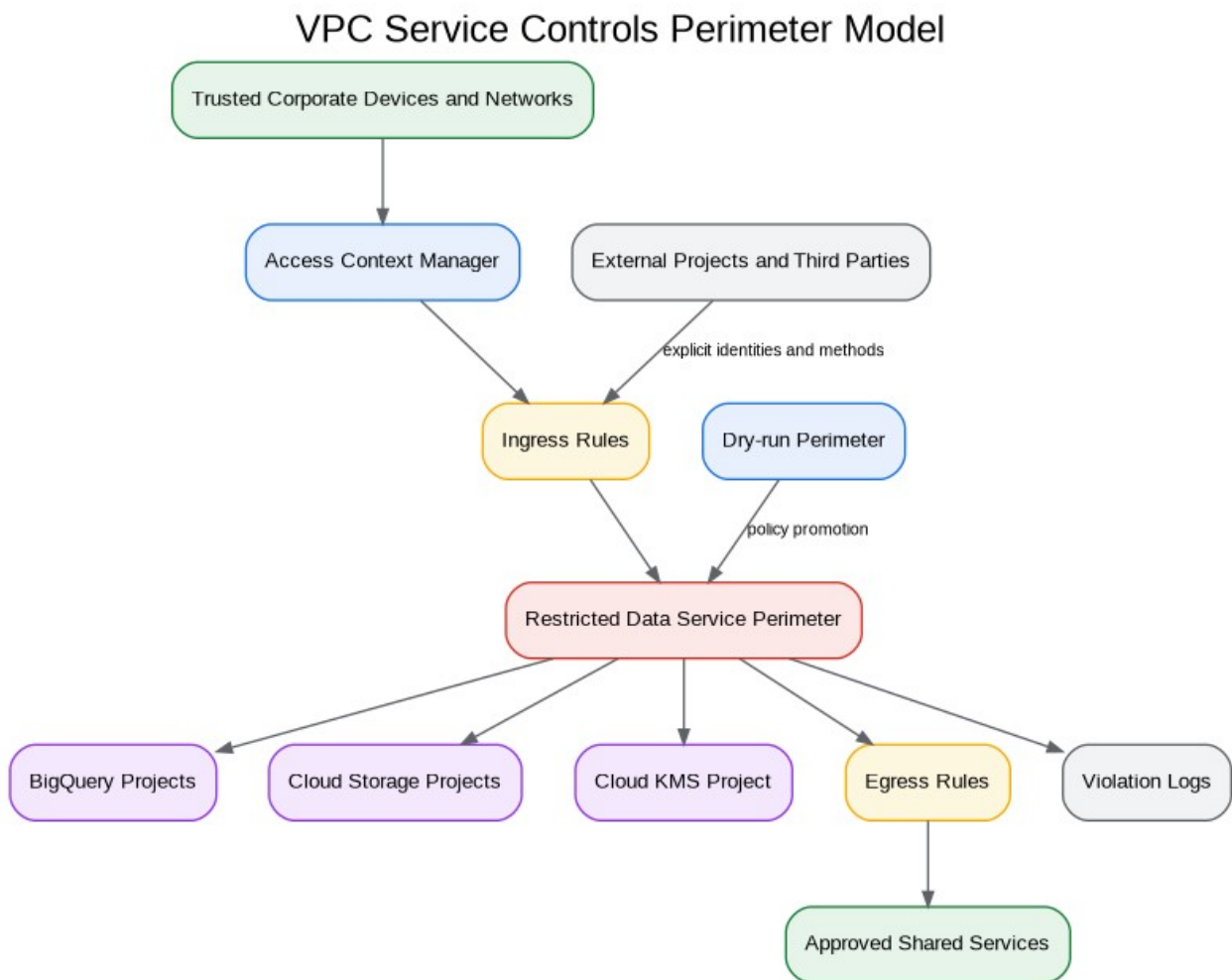
Baseline policy set

Policy intent	Default stance	Exception path
External IPs on VMs	Denied	Approved perimeter or edge project only
Service-account key creation	Denied	Time-bound legacy exception
Service-account key upload	Denied	No standard exception
Domain-restricted sharing	Enterprise domains only	Legal and security approval
Resource locations	Approved region groups	Sovereignty architecture review
Default network creation	Disabled	None
Serial port access	Disabled	Incident-specific approval
OS Login	Required for supported administrative VMs	Documented incompatibility

Policy intent	Default stance	Exception path
Uniform bucket-level access	Required	No standard exception
Public bucket access	Prevented	Dedicated publication project
Shielded VM	Required for applicable VM workloads	Legacy technical exception
CMEK	Required for classified services where policy supports it	Data-risk approval

Policies that could disrupt existing workloads are introduced in observe, dry-run or targeted-folder phases where the product supports such rollout patterns.

6.3 VPC Service Controls



VPC Service Controls

VPC Service Controls reduce the risk of data exfiltration from supported Google-managed services by creating service perimeters and controlling ingress and egress. They complement IAM and do not replace it.

Perimeter model

Perimeter	Example contents	Access pattern
Restricted data	Sensitive BigQuery, Cloud Storage, Dataplex and approved AI projects	Private/restricted API access; narrow ingress and egress

Perimeter	Example contents	Access pattern
General production data	Standard production data projects	Enterprise users and approved services
Security tooling	Security data, findings and forensic storage	Security operations identities only
Development protected	Synthetic or masked development data	Developer groups and approved CI/CD
Bridge	Explicit shared services only	Used sparingly for justified cross-perimeter access

Implementation method

Inventory protected services, clients, identities and data flows.

Define access levels in Access Context Manager.

Create dry-run perimeters and collect violation logs.

Classify violations as required flow, misconfiguration or prohibited access.

Write narrow ingress and egress policies using identities, resources and access levels.

Test user, workload, support, DR and CI/CD paths.

Enforce in staged waves.

Continuously monitor violations and policy drift.

A project belongs to one regular service perimeter at a time. Perimeter bridges and ingress/egress rules are governed centrally because they can materially change data-exfiltration risk.

6.4 Access Context Manager

Access Context Manager defines context-aware access levels used by VPC Service Controls and supported access policies. Signals may include user identity, device state, IP range, geographic context and authentication assurance.

Access levels are designed as reusable controls such as:

corp_managed_device

corp_network_or_vpn

privileged_admin_context

approved_partner_context

breakglass_context

Context is not treated as infallible. Sensitive operations still require IAM, workload authorization and audit.

6.5 Security Command Center

Security Command Center provides centralized asset, vulnerability, misconfiguration and threat findings. The enterprise activates the appropriate service tier based on risk and integrates findings with SIEM, SOAR, ticketing and incident-management workflows.

Operating model

Security owns organization-level activation and finding governance.

Platform teams own remediation of landing-zone findings.

Domain teams own workload findings.

Critical findings page on-call responders.

High findings create tracked incidents within defined time.

Medium and low findings enter risk-based remediation queues.

False-positive suppressions require an owner, rationale and review date.

Posture metrics are reported by folder, domain and control family.

6.6 Secret Manager

Secret Manager stores application secrets, certificates or tokens that cannot be replaced by workload identity. It is not used to store general configuration.

Secret standards

Separate secrets by environment and trust boundary.

Grant access to workload identities, not broad human groups.

Use automatic or scheduled rotation where the dependent system supports it.

Replication policy follows residency and recovery requirements.

Secret payload access logging is enabled and monitored.

Versions are disabled before destruction to support safe rollback.

CI/CD injects secret references, never plaintext values.

Applications cache secrets only for the minimum necessary duration.

6.7 Cloud KMS, Cloud HSM and CMEK

Cloud KMS centralizes cryptographic key lifecycle. Cloud HSM is used where hardware-backed key protection is required. Customer-managed encryption keys are applied according to data classification, regulation and operational capability.

Key hierarchy

Level	Example	Ownership
Key project	prj-kms-prod-amer	Central security platform
Key ring	kr-data-uscentral1-prod	Security platform
Key	key-bq-restricted-customer	Data owner plus security custodian
Crypto role	Encrypter/decrypter for service agent	Narrow service identity
Administration	Rotation and policy administration	Separate key administrators

CMEK decision model

Use CMEK when one or more of the following apply:

Regulation or contract requires customer-controlled keys.

Data is classified restricted or highly confidential.

Cryptographic separation by legal entity or jurisdiction is required.

Key disablement is an approved containment control.

External assurance requires explicit key lifecycle evidence.

Do not use CMEK mechanically without planning key availability, service-agent permissions, regional compatibility, rotation, recovery and incident response. A disabled or inaccessible key can make protected data unavailable.

Separation of duties

Key administrators cannot read protected data solely through key administration.

Data administrators cannot change key policy.

Service agents receive only cryptographic use permissions.

Key destruction requires multiple approvals and retention validation.

Key access and policy changes are centrally logged and alerted.

7. Audit, Monitoring, Logging and Security Operations

7.1 Audit logging

Cloud Audit Logs are aggregated from organization, folder, project and billing scopes as applicable. Admin Activity and System Event logs are retained according to security policy. Data Access logging is enabled based on risk, service capability, volume and regulatory need.

Log classes

Log class	Purpose	Retention guidance	Primary consumers
Admin Activity	Configuration and policy changes	Long-term security retention	Security, audit and platform
Data Access	Reads and writes to protected data	Classification-based	Security, privacy and data governance
System Event	Google system administrative actions	Operational and audit retention	SRE and audit
Policy Denied	Authorization failures	Security retention	Security operations
VPC Flow Logs	Network flow evidence	Risk and cost based	Network and security operations
DNS logs	Name-resolution evidence	High-value networks	Security and network operations
Firewall logs	Rule decisions	High-risk allow/deny rules	Security and network operations

Logging architecture

Organization-level aggregated sinks route logs to centralized logging projects.

Security logs are stored in protected log buckets with restricted writer and reader roles.

Operational logs remain accessible to workload teams through log views or scopes without exposing unrelated domains.

High-volume logs use exclusions only after security and operations review.

Long-term archives use locked retention where legal and forensic requirements justify it.

Log routing failures and sink-writer permissions are monitored.

7.2 Centralized monitoring

Monitoring uses metrics scopes, dashboards, alert policies and SLOs across shared services and workload projects. The landing zone provides standard dashboards and alert modules rather than forcing teams to build from scratch.

Foundation SLOs

Service objective	Example SLI	Target
Hybrid connectivity availability	Healthy redundant attachment minutes / total minutes	99.99% for Tier 0 paths
DNS resolution	Successful enterprise DNS queries / total	99.99%
Project factory lead time	Requests completed within target	95% within 1 business day
Logging completeness	Expected projects delivering required logs	100%
Security finding response	Critical findings acknowledged within target	95% within 15 minutes
IAM review completion	Privileged grants reviewed by due date	100%
Policy compliance	Resources passing mandatory controls	At least 99.5%, with zero unapproved critical exceptions

7.3 Centralized logging design

Centralized logging uses separate projects and buckets for:

Security and audit evidence.

Network telemetry.

Platform operations.

Application and domain operations.

Regulatory archives.

Log views provide least-privilege access without duplicating every log. Log Analytics and BigQuery-linked analysis are used where large-scale correlation is required. Export design accounts for storage, query and retention cost.

7.4 Security operations integration

Security telemetry flows to the enterprise SIEM and SOAR through supported connectors, Pub/Sub, APIs or approved exports. The integration preserves event identifiers, timestamps, resource hierarchy, actor identity, network context and finding severity.

Security event workflow

Google Cloud service or SCC generates an event or finding.

Central routing enriches it with folder, project, domain and owner metadata.

SIEM correlation combines identity, endpoint, network and business context.

SOAR executes approved containment or evidence-gathering actions.

ITSM creates and tracks the incident.

Resource owner and security operations collaborate on remediation.

Control owners review recurring patterns and update guardrails.

Automated remediation is limited to actions with tested rollback and acceptable business impact, such as disabling an exposed key, removing a public policy binding or quarantining a non-production project.

8. Naming Conventions, Labels and Tags

8.1 Naming conventions

Names are deterministic, readable and compatible with service constraints. A logical naming model is maintained even when a service requires globally unique or length-limited identifiers.

Resource	Pattern	Example
Project ID	<org>-<domain>-<purpose>-<env>-<geo>-<nn>	acme-data-cust-prod-amer-01
Folder display name	<Order> - <Purpose>	30 - Production
VPC	vpc-<env>-<geo>-<purpose>	vpc-prod-amer-shared
Subnet	sn-<region>-<purpose>-<nn>	sn-uscentral1-data-01
Router	cr-<region>-<env>-<nn>	cr-uscentral1-prod-01
VPN gateway	havgw-<region>-<site>-<nn>	havgw-uscentral1-dc1-01
Interconnect attachment	vlan-<region>-<site>-<nn>	vlan-uscentral1-dc1-01
PSC endpoint	psc-<service>-<env>-<region>	psc-googleapis-prod-uscentral1
DNS zone	dns-<scope>-<purpose>	dns-prod-services
Service account	sa-<workload>-<function>-<env>	sa-dataflow-run-prod

Resource	Pattern	Example
KMS key ring	kr-<purpose>-<region>-<env>	kr-data-uscentral1-prod
KMS key	key-<service>-<classification>-<domain>	key-bq-restricted-customer
Log bucket	lb-<purpose>-<env>-<geo>	lb-audit-prod-global

Globally unique resources append a controlled numeric or hash suffix. Random strings are generated and persisted by the project factory rather than manually chosen.

8.2 Labels

Labels support cost allocation, operations and inventory. Mandatory labels are validated at deployment.

Label	Example	Purpose
business_domain	customer	Domain ownership
environment	prod	Environment classification
cost_center	cc-1042	Financial allocation
application_id	app-02871	CMDB correlation
data_classification	restricted	Security and governance
owner	customer-platform	Accountable team
managed_by	terraform	Configuration authority
criticality	tier1	Reliability and response
region_group	amer	Residency and reporting
expiry_date	2027-06-30	Sandbox or exception lifecycle

8.3 Resource Manager tags

Tags are used when inherited policy or conditional IAM depends on business context. Example tag keys include:

environment/prod

data-classification/restricted

internet-exposure/approved

csek-or-cmek/required

service-perimeter/restricted-data

retention/legal-hold

Tag values are governed because they can affect policy. Workload teams cannot freely assign security-sensitive tags.

9. Terraform Landing-Zone Implementation

9.1 Infrastructure-as-Code architecture

Terraform is the system of record for organization structure, projects, networks, IAM, policies, logging, monitoring, encryption and service perimeters. Pipelines use short-lived federated credentials and separate plan from apply.

Repository structure

```

landing-zone/
├─ bootstrap/
│   └─ state/
│   └─ cicd/
└─ seed-project/

```

```

├─ modules/
│   ├─ organization/
│   │   └─ folder/
│   │       └─ project-factory/
│   │           └─ shared-vpc/
│   │               └─ hybrid-connectivity/
│   │                   └─ dns/
│   │                       └─ firewall-policy/
│   │                           └─ iam/
│   │                               └─ org-policy/
│   │                                   └─ logging/
│   │                                       └─ monitoring/
│   │                                           └─ kms/
│   │                                               └─ secret-manager/
│   │                                                   └─ vpc-service-controls/
│   │                                                       └─ security-command-center/
│   └─ environments/
│       └─ dev/
│           └─ nonprod/
│               └─ prod/
│   └─ geographies/
│       └─ amer/
│           └─ emea/
│               └─ apac/
│   └─ policies/
│   └─ tests/
│   └─ examples/
│   └─ docs/

```

9.2 Module standards

Every reusable module includes:

Purpose and architecture ownership.

Supported provider and Terraform versions.

Inputs with validation.

Outputs required for composition.

Secure defaults.

Optional capabilities that do not weaken mandatory controls.

Unit/static tests.

Integration test fixture.

Example usage.

Upgrade and rollback notes.

Known limitations.

Versioned release notes.

Module catalog

Module	Primary resources	Key controls
Project factory	Project, billing, APIs, labels and IAM	Naming, owner, log sinks and policy inheritance
Shared VPC	Network, subnet, routes and service-project attachment	Private access, flow logs and delegated subnet use
Firewall policy	Hierarchical/network rules	Priority ranges, logging and exceptions

Module	Primary resources	Key controls
Logging	Aggregated sinks, buckets and views	Retention, restricted readers and routing health
KMS	Key projects, rings, keys and IAM	Separation of duties and rotation
VPC SC	Access policies, perimeters and rules	Dry run, narrow ingress/egress and validation
Monitoring	Scopes, dashboards and alerts	SLOs, paging and ownership
Identity	Groups, service accounts and IAM	Least privilege and federation

9.3 Project factory example

The complete reusable example is included in terraform/modules/project_factory within the package. The pattern below shows the composition intent.

```
module "domain_project" {
  source = "../../modules/project_factory"

  project_id    = "acme-data-cust-prod-amer-01"
  name          = "Customer Data Production"
  folder_id     = var.production_folder_id
  billing_account = var.billing_account
  environment    = "prod"
  business_domain = "customer"
  cost_center    = "cc-1042"
  application_id = "app-02871"
  data_classification = "restricted"
  shared_vpc_host = var.prod_amer_host_project
  subnet_self_links = [var.data_subnet]
  perimeter_name   = var.restricted_data_perimeter
  activate_apis = [
    "bigquery.googleapis.com",
    "storage.googleapis.com",
    "logging.googleapis.com",
    "monitoring.googleapis.com"
  ]
}
```

9.4 Organization-policy example

```
name: organizations/123456789/policies/iam.disableServiceAccountKeyCreation
spec:
  rules:
    - enforce: true
```

Policies in the package are examples and must be reconciled with current constraint names, inherited policy state and service dependencies before apply.

9.5 IAM example

```
bindings:
  - role: roles/compute.networkUser
  members:
    - serviceAccount:sa-dataflow-run-prod@acme-data-cust-prod-amer-01.iam.gserviceaccount.com
  condition:
    title: approved_data_subnet
    expression: resource.name.startsWith("projects/prj-net-prod-amer/regions/us-central1/subnetworks/sn-uscentral1-data")
```

The actual condition syntax and resource support must be tested against the target API and policy version.

9.6 Firewall-policy example

```
rules:
- priority: 1000
  direction: INGRESS
  action: deny
  sourceRanges: ["0.0.0.0/0"]
  layer4Configs:
  - ipProtocol: all
  targetResources:
  - tagValues/INTERNET_ADMIN_PROHIBITED
  enableLogging: true
```

The package includes a more complete example with rule ownership and exception metadata.

9.7 CI/CD controls

The landing-zone pipeline performs:

Formatting and linting.

Provider and module version checks.

Terraform validation.

Static security analysis.

Policy-as-code evaluation.

Unit and contract tests.

Plan generation in a controlled execution project.

Human approval for production-impacting changes.

Apply using a dedicated deployment identity.

Post-deployment verification.

Evidence publication and CMDB update.

Drift monitoring.

Production applies are not executed from developer workstations.

10. Landing-Zone Deployment Sequence

10.1 Deployment waves

Wave	Scope	Exit evidence
0	Governance and prerequisites	Executive sponsor, owners, billing, domain and region decisions
1	Bootstrap	State storage, seed project, federated CI/CD and audit trail
2	Organization hierarchy	Folders, groups, baseline IAM and resource-location policy
3	Security foundation	Organization policies, SCC, logging sinks, KMS and break glass
4	Network foundation	Shared VPCs, IPAM, DNS, firewall and private API access
5	Hybrid connectivity	Redundant Interconnect/VPN, route controls and tested failover
6	Project factory	Automated project creation, labels, APIs, IAM and registrations

Wave	Scope	Exit evidence
7	Service perimeters	Dry-run, remediation and staged enforcement
8	Operations	Monitoring, SLOs, SIEM/SOAR and runbooks
9	Pilot workloads	Representative data, application and AI projects
10	Scale-out	Domain onboarding, controls assurance and continuous improvement

10.2 Detailed sequence

Phase A — Mobilize

Confirm organization ownership and super-administrator recovery.
 Establish architecture, security, network, identity, operations and FinOps workstreams.
 Confirm billing accounts, contracts, support tier and escalation paths.
 Inventory current Google Cloud organizations and shadow projects.
 Approve region groups, residency classes and workload tiers.

Phase B — Bootstrap

Create seed project and protected Terraform state.
 Establish federated CI/CD identity.
 Configure code repositories, approvals and artifact retention.
 Deploy initial audit log routing.
 Create break-glass accounts and validate recovery process.

Phase C — Hierarchy and guardrails

Create folders and attach baseline IAM.
 Deploy organization policies in staged waves.
 Activate Security Command Center.
 Establish KMS, logging and security projects.
 Configure central alerting and SIEM integration.

Phase D — Network and identity

Deploy Shared VPC host projects and subnets.
 Configure DNS, private API access, PSC and NAT.
 Deploy firewall policies and connectivity hubs.
 Establish hybrid links and validate route failover.
 Federate workforce and workload identities.

Phase E — Factory and operations

Deploy the project factory and service modules.
 Integrate CMDB, IPAM, ticketing, billing and ownership systems.
 Define service perimeters in dry-run mode.
 Build dashboards, SLOs, alerts and runbooks.
 Onboard representative pilot workloads.

Phase F — Enforce and scale

Resolve dry-run violations and enforce perimeters.

Conduct security and production-readiness reviews.

Validate disaster recovery and break-glass procedures.

Roll out domain onboarding waves.

Operate quarterly control assurance and improvement reviews.

11. Landing-Zone Validation Checklist

11.1 Governance and hierarchy

ID	Validation	Acceptance evidence
GOV-01	One authoritative organization is established	Organization record and owner approval
GOV-02	Folder hierarchy maps to durable governance boundaries	Approved hierarchy diagram and policy mapping
GOV-03	Production and non-production are separated	Folder/project inventory and IAM review
GOV-04	Every project has an owner, cost center and lifecycle	Project factory record and labels
GOV-05	Exceptions have expiry and compensating controls	Exception register

11.2 Network

ID	Validation	Acceptance evidence
NET-01	Shared VPC host projects are centrally administered	IAM policy and network inventory
NET-02	Address ranges do not overlap routed enterprise networks	IPAM report and route test
NET-03	Private Google Access is enabled on private subnets	Subnet configuration test
NET-04	DNS resolves enterprise and private API names redundantly	Resolution and failure tests
NET-05	Firewall policy blocks unapproved administrative ingress	Negative connectivity test
NET-06	Hybrid links survive single device and path failures	Failover test report
NET-07	NAT capacity supports measured peak load	Load test and port metrics
NET-08	Flow and firewall logs reach central security projects	Log query evidence

11.3 Identity and IAM

ID	Validation	Acceptance evidence
IAM-01	Workforce access is federated and MFA enforced	IdP policy and access test
IAM-02	No routine basic Owner/Editor grants exist	IAM analyzer report
IAM-03	CI/CD uses federated short-lived credentials	Token exchange and deployment logs

ID	Validation	Acceptance evidence
IAM-04	Service-account key creation is prevented	Organization policy and negative test
IAM-05	Privileged access is time-bound and approved	PAM entitlement and completed request
IAM-06	Break-glass access is independently recoverable	Controlled test record
IAM-07	Privileged groups have owners and review schedules	Identity governance evidence

11.4 Security and data perimeter

ID	Validation	Acceptance evidence
SEC-01	Baseline organization policies are enforced	Policy inventory and compliance scan
SEC-02	SCC findings route to accountable owners	Sample incident and routing evidence
SEC-03	Restricted projects are inside approved service perimeters	Perimeter inventory
SEC-04	Required ingress/egress paths pass and unapproved paths fail	Test matrix
SEC-05	CMEK-protected services can encrypt/decrypt after rotation	Rotation test
SEC-06	Key disablement alert and recovery are tested	Exercise report
SEC-07	Secret access is least privilege and audited	IAM and log review

11.5 Logging, monitoring and operations

ID	Validation	Acceptance evidence
OPS-01	All projects route mandatory logs centrally	Coverage dashboard
OPS-02	Log buckets enforce required retention	Bucket policy evidence
OPS-03	Foundation SLOs and alerts are active	Dashboard and alert test
OPS-04	Critical alerts reach 24x7 responders	Paging exercise
OPS-05	Runbooks contain ownership, diagnosis and rollback	Approved runbook library
OPS-06	SIEM receives identity, network and SCC telemetry	Event correlation evidence
OPS-07	Terraform drift is detected and triaged	Drift report and ticket

11.6 Project factory

ID	Validation	Acceptance evidence
FAC-01	A standard project is provisioned end-to-end automatically	Pipeline record and created project
FAC-02	Naming, labels and billing are validated	Resource inventory
FAC-03	Shared VPC attachment and subnet IAM are correct	Network test

ID	Validation	Acceptance evidence
FAC-04	Logging, monitoring and SCC registration are automatic	Coverage evidence
FAC-05	Project deletion uses hold, approval and recovery window	Lifecycle test
FAC-06	Sandbox expiry and quotas are enforced	Automated cleanup evidence

12. Architecture Decision Records

ADR-LZ-001 — Single authoritative Google Cloud organization

Problem. Multiple independent organizations fragment policy, identity, billing and audit control.

Alternatives. One enterprise organization; multiple organizations by business unit; multiple organizations by geography.

Decision. Use one authoritative enterprise organization, with separate organizations only where legal ownership or sovereign administration requires them.

Tradeoffs. Central governance improves consistency but requires clear delegation and scalable automation.

Risks. Central teams could become a bottleneck; organization-level mistakes have wide impact.

Mitigations. Policy as code, staged deployment, delegated folders, peer review, break-glass recovery and blast-radius testing.

ADR-LZ-002 — Folder hierarchy by governance boundary

Problem. Organizing folders only by current reporting lines causes policy instability during reorganizations.

Alternatives. Business-unit-first; environment-first; geography-first; hybrid governance-boundary hierarchy.

Decision. Use durable control boundaries: platform and shared services, production, non-production, sandbox and regulated geography overlays.

Tradeoffs. Some business reporting requires labels and inventory queries rather than folder ancestry.

Risks. Over-complex nesting could obscure inherited policy.

Mitigations. Limit depth, publish policy maps and test effective policy automatically.

ADR-LZ-003 — Automated project factory

Problem. Manual project creation creates inconsistent controls and slow onboarding.

Alternatives. Manual console process; ticket-driven scripts; reusable Terraform project factory.

Decision. Use a Terraform-based factory triggered by a governed request and approval workflow.

Tradeoffs. Upfront engineering and integration are required.

Risks. A defective module can replicate errors broadly.

Mitigations. Versioned modules, test fixtures, staged releases, canaries and automated post-deployment verification.

ADR-LZ-004 — Centralized Shared VPC

Problem. Independent workload networks create inconsistent routing, DNS, firewall and hybrid connectivity.

Alternatives. Standalone VPC per project; VPC peering mesh; centralized Shared VPC by environment and geography.

Decision. Use centralized Shared VPC host projects with delegated subnet use.

Tradeoffs. Network changes require platform coordination and strong service interfaces.

Risks. Central network team becomes a bottleneck; misconfiguration has broad impact.

Mitigations. Self-service modules, policy automation, regional separation and tested change windows.

ADR-LZ-005 — Regionalized network and data foundations

Problem. A single global design may conflict with sovereignty and recovery requirements.

Alternatives. One global network; separate network per region; regional Shared VPCs grouped by geography.

Decision. Use regional subnets and geography-aligned host projects, with controlled global connectivity.

Tradeoffs. More network objects and operational coordination.

Risks. Configuration divergence between geographies.

Mitigations. Common modules, conformance tests and centrally governed exceptions.

ADR-LZ-006 — Private access by default

Problem. Public IPs and direct internet paths increase attack surface and exfiltration risk.

Alternatives. Public endpoints with firewall controls; private access for selected systems; private-first landing zone.

Decision. Use private workload addresses, Private Google Access, PSC and controlled egress by default.

Tradeoffs. Some SaaS and legacy integrations require additional proxies or exceptions.

Risks. Hidden service dependencies can fail during enforcement.

Mitigations. Dependency discovery, staged rollout, service-specific testing and approved exception patterns.

ADR-LZ-007 — Interconnect primary, HA VPN complementary

Problem. Fortune 100 data movement requires predictable capacity and resilient connectivity.

Alternatives. Internet only; HA VPN only; Interconnect only; Interconnect with HA VPN backup.

Decision. Use redundant Dedicated or Partner Interconnect for strategic sites and HA VPN for backup, branches and rapid onboarding.

Tradeoffs. Higher cost and operational complexity than internet connectivity.

Risks. Carrier or colocation dependencies and asymmetric routing.

Mitigations. Diverse paths, devices, providers, route policy and recurring failover tests.

ADR-LZ-008 — Workforce and workload federation

Problem. Long-lived Google credentials and service-account keys increase theft and lifecycle risk.

Alternatives. Local Google accounts and keys; directory synchronization only; workforce/workload federation.

Decision. Federate workforce and external workload identities, using short-lived credentials.

Tradeoffs. Dependency on external identity providers and token configuration.

Risks. IdP outage or incorrect claim mapping blocks access or broadens trust.

Mitigations. Redundant IdP design, claim tests, break glass and conservative attribute conditions.

ADR-LZ-009 — Time-bound privileged access

Problem. Permanent high privilege increases abuse and compromise impact.

Alternatives. Standing admin groups; manual temporary grants; Privileged Access Manager entitlements.

Decision. Use time-bound, approved elevation for routine privileged activity and minimal standing emergency access.

Tradeoffs. Approval introduces lead time for administrative work.

Risks. Emergency response may be delayed.

Mitigations. Predefined emergency entitlements, 24x7 approvers and break-glass procedure.

ADR-LZ-010 — Organization-policy guardrails

Problem. Detective controls alone allow high-risk configurations to be deployed.

Alternatives. Documentation only; post-deployment scanning; preventive organization policies plus detection.

Decision. Enforce a tested baseline of preventive constraints with governed exceptions.

Tradeoffs. Some services or migrations require temporary exceptions.

Risks. Policy rollout can break production dependencies.

Mitigations. Inventory, policy simulation where supported, staged folders, canary projects and rollback.

ADR-LZ-011 — VPC Service Controls for sensitive managed services

Problem. IAM compromise or misconfiguration can enable data movement to unauthorized resources.

Alternatives. IAM only; network controls only; VPC SC around selected protected services.

Decision. Use VPC SC for restricted and high-value data projects with explicit ingress/egress rules.

Tradeoffs. Integration complexity and service compatibility constraints.

Risks. Broken user, CI/CD or managed-service workflows.

Mitigations. Dry-run mode, flow inventory, automated tests and centrally governed policy changes.

ADR-LZ-012 — Selective CMEK and HSM

Problem. Some workloads require customer-controlled or hardware-backed encryption keys.

Alternatives. Google-managed keys for all; CMEK for all; risk-based CMEK and HSM.

Decision. Apply CMEK and HSM based on classification, regulation and contractual need.

Tradeoffs. Key lifecycle and availability become customer responsibilities.

Risks. Disabled, destroyed or inaccessible keys cause data unavailability.

Mitigations. Separation of duties, rotation tests, protected key projects, monitoring and recovery procedures.

ADR-LZ-013 — Centralized log routing with delegated views

Problem. Project-local logs can be altered, inconsistently retained or inaccessible during incidents.

Alternatives. Local logging only; copy all logs to one project; aggregated sinks with protected buckets and views.

Decision. Use organization/folder aggregated sinks, protected buckets and delegated log views/scopes.

Tradeoffs. Central storage and query costs require active management.

Risks. Excessive central access or routing gaps.

Mitigations. Least-privilege views, coverage monitoring, retention tiers and controlled exclusions.

ADR-LZ-014 — Security Command Center as cloud posture hub

Problem. Findings from assets, vulnerabilities and threats need centralized ownership and response.

Alternatives. Independent service alerts; third-party CSPM only; SCC integrated with enterprise SIEM/SOAR.

Decision. Use SCC as the Google Cloud posture and finding hub, integrated with enterprise operations.

Tradeoffs. Requires tuning, ownership mapping and possible premium-service cost.

Risks. Alert fatigue and unresolved findings.

Mitigations. Severity policy, suppression governance, automated enrichment and remediation SLOs.

ADR-LZ-015 — Terraform as configuration authority

Problem. Manual changes create drift, weak auditability and inconsistent recovery.

Alternatives. Console-first; scripts; declarative Terraform with controlled pipelines.

Decision. Manage landing-zone resources through versioned Terraform and policy-as-code.

Tradeoffs. Module maintenance and state governance are required.

Risks. State compromise, destructive plans or provider regressions.

Mitigations. Protected remote state, pinned versions, plan review, backups and staged upgrades.

13. Service Reference Cards

The following cards summarize how the principal landing-zone services are used. Quotas, availability and features must be verified against current product documentation before implementation.

13.1 Shared VPC

Purpose and role. Centralizes network ownership while allowing workload resources to reside in service projects.

Benefits. Consistent IPAM, routing, DNS, firewall, logging and hybrid connectivity; separation of network administration from workload administration.

Limitations. Requires delegated subnet permissions and careful service-agent IAM; some products have service-specific network requirements.

Alternatives. Standalone VPCs, peering, Network Connectivity Center spokes.

Security and monitoring. Restrict host-project administration, enable flow logs, monitor route and firewall changes, and use policy validation.

Cost optimization. Shared connectivity avoids duplicate NAT, VPN and appliance footprints; flow-log volume must be tuned.

Pitfalls. Over-centralization without self-service, broad network-user grants and generic subnets.

13.2 Private Service Connect

Purpose and role. Exposes or consumes supported services through private endpoints across network boundaries.

Benefits. Producer-consumer isolation, no broad peering and stable service endpoints.

Limitations. Product and region support varies; DNS and endpoint quotas require planning.

Alternatives. Private Google Access, VPC peering, public endpoint with strong controls.

Security and monitoring. Approve producers/consumers, apply IAM and application authentication, and monitor connection status.

Cost optimization. Consolidate endpoints where trust and ownership permit; avoid unused regional endpoint sprawl.

Pitfalls. Treating reachability as authorization and neglecting DNS rollback.

13.3 Cloud NAT

Purpose and role. Provides managed outbound translation for private resources.

Benefits. No inbound exposure, regional managed operation and scalable address translation.

Limitations. No payload inspection or domain filtering; port capacity must be managed.

Alternatives. Secure web proxy, firewall appliance, public IP, PSC/private APIs.

Security and monitoring. Restrict eligible subnets, log errors, alert on port exhaustion and analyze destinations.

Cost optimization. Right-size external addresses and logging; remove internet dependency where private endpoints exist.

Pitfalls. Assuming NAT equals egress security and ignoring port consumption.

13.4 Cloud DNS

Purpose and role. Provides authoritative and forwarding DNS for enterprise cloud resources.

Benefits. Managed availability, private zones, policies and hybrid forwarding.

Limitations. Complex split-horizon and overlapping-zone designs can produce unexpected resolution.

Alternatives. On-premises-only resolvers or third-party DNS appliances.

Security and monitoring. Control zone administration, log high-value queries and protect public-zone changes.

Cost optimization. Apply query logging selectively based on risk and use centralized reusable zones.

Pitfalls. Circular forwarding, ambiguous zones and unmanaged manual records.

13.5 Cloud Interconnect

Purpose and role. Provides private high-throughput connectivity between enterprise networks and Google Cloud.

Benefits. Predictable performance and private routing for high-volume hybrid workloads.

Limitations. Lead time, physical/provider dependencies and customer routing responsibility.

Alternatives. HA VPN, internet-secured APIs, partner-managed connectivity.

Security and monitoring. Use redundant attachments, route controls, encryption where required, and BGP/attachment monitoring.

Cost optimization. Size capacity from measured traffic and commitments; avoid unnecessary cross-region transfer.

Pitfalls. Single facility/provider dependence and untested failover.

13.6 HA VPN

Purpose and role. Provides encrypted IPsec connectivity for branches, backup and lower-throughput hybrid paths.

Benefits. Rapid deployment, managed gateways and dynamic routing.

Limitations. Internet path variability and tunnel throughput constraints.

Alternatives. Interconnect, partner connectivity and secure public APIs.

Security and monitoring. Strong cryptography, redundant tunnels, BGP monitoring and key lifecycle governance.

Cost optimization. Use for appropriate traffic profiles rather than overbuilding physical connectivity.

Pitfalls. Single tunnel, asymmetric routing and lack of capacity testing.

13.7 Cloud Armor

Purpose and role. Protects supported load-balanced applications from web attacks and abuse.

Benefits. Managed WAF controls, rate limiting and integration with Google's edge.

Limitations. Requires supported load-balancing architecture; tuning is application specific.

Alternatives. Third-party WAF, API gateway policy and application-native controls.

Security and monitoring. Deploy baseline plus application policy, use preview, monitor false positives and integrate logs with SIEM.

Cost optimization. Reuse hierarchical baselines and tune verbose logging appropriately.

Pitfalls. Enabling rules without preview and assuming WAF replaces secure development.

13.8 Workforce Identity Federation

Purpose and role. Grants external workforce identities controlled access without permanent Google accounts.

Benefits. Short-lived credentials, external lifecycle ownership and attribute-based trust.

Limitations. Depends on identity-provider claims and supported access patterns.

Alternatives. Managed Google accounts or partner-specific identity provisioning.

Security and monitoring. Immutable subject mapping, MFA, narrow attribute conditions and token audit.

Cost optimization. Reduces account lifecycle overhead and orphaned identities.

Pitfalls. Broad claim mappings and mutable identifiers.

13.9 Workload Identity Federation

Purpose and role. Allows external workloads and CI/CD systems to exchange external credentials for short-lived Google credentials.

Benefits. Eliminates most service-account keys and improves attribution.

Limitations. Token issuer, audience and attribute configuration must be precise.

Alternatives. Service-account keys, attached service accounts or intermediary brokers.

Security and monitoring. Restrict repository, branch, environment, account and workload claims; monitor impersonation.

Cost optimization. Reduces key-rotation and incident-management overhead.

Pitfalls. Trusting an entire external organization when only one repository or workload is needed.

13.10 Privileged Access Manager

Purpose and role. Provides approved, time-bound elevation to privileged roles.

Benefits. Reduces standing privilege and connects access to business justification.

Limitations. Coverage, roles and workflow must be tested for each administrative use case.

Alternatives. Manual temporary IAM grants or permanent admin groups.

Security and monitoring. Independent approvers, short duration, post-use review and alerting.

Cost optimization. Reduces risk and audit effort rather than direct infrastructure cost.

Pitfalls. Entitlements that are too broad or approvals that become rubber stamps.

13.11 VPC Service Controls

Purpose and role. Creates service perimeters around supported managed services to reduce exfiltration risk.

Benefits. Context- and identity-aware ingress/egress controls beyond IAM.

Limitations. Supported-service boundaries, integration complexity and one regular perimeter per project.

Alternatives. IAM, network controls and separate organizations, none equivalent by themselves.

Security and monitoring. Dry-run rollout, violation analysis and centrally reviewed ingress/egress rules.

Cost optimization. Primary value is risk reduction; minimize unnecessary perimeter fragmentation and operational toil.

Pitfalls. Enforcing before flow discovery and using broad wildcard rules.

13.12 Security Command Center

Purpose and role. Centralizes cloud posture, asset, vulnerability and threat findings.

Benefits. Organization-wide visibility and integrated Google Cloud context.

Limitations. Finding quality depends on activation, tier, service coverage and ownership mapping.

Alternatives. Third-party CSPM/CNAPP or service-specific alerts.

Security and monitoring. Integrate with SIEM/SOAR, set remediation SLOs and govern suppressions.

Cost optimization. Select service tier according to risk and avoid duplicative integrations without purpose.

Pitfalls. Activating findings without a response operating model.

13.13 Secret Manager

Purpose and role. Stores and versions secrets that cannot be replaced by identity federation.

Benefits. IAM-controlled access, replication, rotation support and auditability.

Limitations. Applications must implement safe retrieval, caching and rotation handling.

Alternatives. External vault or workload-native credentials.

Security and monitoring. Narrow access, access logging, rotation and disabled-before-destroy lifecycle.

Cost optimization. Remove unused versions and avoid polling excessively.

Pitfalls. Storing ordinary configuration, granting project-wide secret access and embedding payloads in CI logs.

13.14 Cloud KMS and Cloud HSM

Purpose and role. Manage cryptographic keys and hardware-backed key material for protected services.

Benefits. Central lifecycle, IAM, rotation, audit and service integrations.

Limitations. Customer operational responsibility and service/region compatibility.

Alternatives. Google-managed encryption or external key management.

Security and monitoring. Separate key and data administration, monitor use and policy changes, test rotation and recovery.

Cost optimization. Apply HSM and CMEK based on classification, not indiscriminately.

Pitfalls. Key project in same administrative boundary as data, missing service-agent grants and destructive key actions without safeguards.

13.15 Cloud Logging

Purpose and role. Collects, routes, stores and analyzes platform and audit logs.

Benefits. Native service integration, aggregated sinks, log buckets, views and alerting.

Limitations. High-volume logs can create material storage and query cost.

Alternatives. Third-party log platform with export, though native audit collection remains foundational.

Security and monitoring. Protected buckets, route health alerts, least-privilege views and retention controls.

Cost optimization. Tier retention, use justified exclusions and avoid duplicate exports.

Pitfalls. Disabling high-value logs solely for cost and granting broad log-view access.

13.16 Cloud Monitoring

Purpose and role. Provides metrics, dashboards, alerting and SLO monitoring.

Benefits. Native Google Cloud telemetry and cross-project metrics scopes.

Limitations. Custom metrics and alert design require governance to avoid cost and noise.

Alternatives. External observability platform or Prometheus-based stacks.

Security and monitoring. Separate metric writers/readers, standardize alert routing and test notifications.

Cost optimization. Control custom metric cardinality and dashboard duplication.

Pitfalls. Alerts without runbooks, ownership or actionable thresholds.

14. Operating Model and RACI

14.1 Responsibility model

Capability	Cloud platform	Network	Security	Identity	Domain team	SRE/ Operations	FinOps
Organization hierarchy	A/R	C	C	C	I	I	C
Project factory	A/R	C	C	C	C	C	C
Shared VPC	C	A/R	C	I	I	C	I
Hybrid connectivity	I	A/R	C	I	I	C	C
IAM standards	C	I	A	R	C	C	I
Organization policy	R	C	A	C	I	C	I
VPC Service Controls	R	C	A	C	C	C	I
Logging foundation	R	C	A	I	C	C	C
Monitoring foundation	R	C	C	I	C	A	C
KMS	C	I	A/R	I	C	C	C

Capability	Cloud platform	Network	Security	Identity	Domain team	SRE/ Operations	FinOps
Cost allocation	C	I	I	I	R	C	A
Workload onboarding	R	C	C	C	A	C	C

A = Accountable, R = Responsible, C = Consulted, I = Informed.

14.2 Service ownership

Every landing-zone service has:

Executive sponsor.

Product owner.

Technical owner.

Security control owner.

24x7 support owner where required.

SLO and error budget.

Roadmap and lifecycle.

Cost owner.

Runbook and escalation path.

15. Risks and Mitigations

ID	Risk	Probability	Impact	Mitigation
LZ-R01	Central platform becomes onboarding bottleneck	Medium	High	Product factory, APIs, service catalog and SLOs
LZ-R02	Organization policy disrupts legacy workloads	Medium	Critical	Inventory, staged rollout, canaries and rollback
LZ-R03	Overlapping multi-cloud address space blocks routing	High	High	Enterprise IPAM and service-level integration
LZ-R04	VPC SC blocks valid managed-service flows	Medium	High	Dry run, flow tests and narrow policies
LZ-R05	Standing privileged access is compromised	Medium	Critical	PAM, MFA, group reviews and break glass
LZ-R06	Key mismanagement makes data unavailable	Low	Critical	Separation, rotation tests, alerts and recovery
LZ-R07	Central logging cost grows unexpectedly	Medium	Medium	Retention tiers, exclusions governance and budgets
LZ-R08	Hybrid carrier failure causes regional outage	Medium	High	Diverse attachments, VPN backup and failover tests

ID	Risk	Probability	Impact	Mitigation
LZ-R09	Terraform module defect creates broad misconfiguration	Medium	High	Versioning, test fixtures, canaries and plan review
LZ-R10	Acquired companies create shadow organizations	High	High	M&A discovery, transition pattern and governance mandate
LZ-R11	Service-account keys persist in legacy systems	High	High	Inventory, deny new keys, federation migration and expiry
LZ-R12	Security findings lack accountable owners	Medium	High	Resource metadata, routing rules and remediation SLOs

16. Production Readiness Review

A landing-zone release is production ready only when:

Architecture decisions are approved and recorded.

Terraform source, state and pipelines are protected.

Project-factory request and rollback paths are tested.

Identity federation and break-glass recovery are tested.

Hybrid connectivity survives documented failures.

DNS, routing, firewall and private access tests pass.

Logging coverage is complete and retention is verified.

Monitoring alerts reach accountable responders.

VPC SC dry-run violations are resolved or approved.

CMEK rotation and failure behavior are tested.

Organization policies are validated against representative workloads.

Security findings route into operational workflows.

CMDB, IPAM, billing and ownership integrations reconcile.

Runbooks are approved and exercised.

Disaster recovery dependencies are documented.

FinOps budgets and allocation metadata are active.

Exceptions have owners, compensating controls and expiry.

Appendix A — Example Artifact Inventory

The accompanying package contains:

Seven diagrams in Draw.io, Mermaid, PlantUML, Graphviz DOT, SVG and PNG.

Terraform bootstrap and reusable landing-zone modules.

Project-factory, Shared VPC, organization-policy, logging, KMS and VPC SC examples.

Cloud Build pipeline example.

IAM, firewall-policy and organization-policy YAML examples.

Editable DOCX and polished PDF versions of this volume.

Appendix B — Glossary

Term	Definition
Landing zone	Governed cloud foundation for secure workload deployment
Host project	Project that owns a Shared VPC network
Service project	Project attached to a Shared VPC and containing workload resources
Project factory	Automated workflow that provisions compliant projects
Service perimeter	VPC Service Controls boundary for supported services
Access level	Context definition used for context-aware access controls
CMEK	Customer-managed encryption key
PSC	Private Service Connect
PAM	Privileged Access Manager
SLI	Service level indicator
SLO	Service level objective
RTO	Recovery time objective
RPO	Recovery point objective

Appendix C — Quality Assurance Checklist

All requested landing-zone topics are addressed.

Diagram source formats are editable.

Examples contain no production secrets or real identifiers.

Naming is consistent across narrative, diagrams and Terraform.

Security controls identify owners and evidence.

Architecture decisions include alternatives, tradeoffs, risks and mitigations.

Service cards identify limitations and common pitfalls.

Product features and constraints are marked for current-documentation validation.

DOCX and PDF are visually inspected after rendering.

Package contains checksums and a manifest.

Appendix D — Control Evidence Catalogue

Control area	Design evidence	Deployment evidence	Operating evidence
Resource hierarchy	Approved hierarchy and inheritance map	Terraform plan and resource inventory	Quarterly ownership review
Project factory	Service design and request schema	Pipeline logs and test project	Lead-time SLO and exception metrics
Shared VPC	Network architecture and IPAM allocation	Host/service project attachment	Route, firewall and capacity dashboards
Hybrid connectivity	Resilience and route design	Attachment, VPN and BGP configurations	Failover exercises and availability SLI

Control area	Design evidence	Deployment evidence	Operating evidence
Identity federation	Trust model and claim mapping	Pool/provider and IAM configuration	Token and access-review evidence
Privileged access	Entitlement and approval design	PAM configuration	Request, use and expiry records
Organization policy	Policy baseline and exception model	Effective-policy inventory	Compliance and exception review
VPC Service Controls	Perimeter and flow matrix	Dry-run and enforced policies	Violation dashboard and rule review
Encryption	Key hierarchy and classification mapping	KMS, HSM and IAM configuration	Rotation, access and recovery tests
Logging	Log-source and retention matrix	Aggregated sinks, buckets and views	Coverage, retention and query evidence
Monitoring	SLI/SLO and alert catalogue	Dashboards and alert policies	Alert tests, incidents and error budgets
Security operations	Finding ownership and response model	SCC and SIEM/SOAR connectors	Remediation SLO and incident records

Appendix E — Authoritative Implementation References

The implementation team must validate current behavior against the latest official Google Cloud documentation. The principal reference families are:

Google Cloud landing zone design and deployment guidance.

Google Cloud enterprise foundations blueprint.

Resource hierarchy and organization policy documentation.

Shared VPC, VPC design and Network Connectivity Center documentation.

Private Service Connect and Private Google Access documentation.

Cloud Interconnect, Partner Interconnect and HA VPN documentation.

Cloud DNS, Cloud NAT and Cloud Armor documentation.

Cloud Identity, Workforce Identity Federation and Workload Identity Federation documentation.

IAM, service accounts, IAM Conditions and Privileged Access Manager documentation.

VPC Service Controls and Access Context Manager documentation.

Security Command Center documentation.

Secret Manager, Cloud KMS, Cloud HSM and CMEK integration documentation.

Cloud Audit Logs, Log Router, log buckets, log scopes and Cloud Monitoring documentation.

Terraform Google provider and Google Cloud foundation toolkit examples.

Reference validation is a release gate because service support, constraints, quotas and recommended patterns can change after this architecture baseline is published.